VULNERABILITY ASSESSMENT REPORT

GRC Lab 1 | Practical Vulnerability Assessment

Name	Oluwatosin Olajubu
Registration Number	C11/26/CGRCE/217602
Assessment target	Metasploitable test server (hostname metasploitable.localdomain)
Target IP address	192.168.164.129
Scanner host	Kali Linux, 192.168.164.128
Assessment date	22 October 2026 (scans); Nmap 04:57-05:00 EDT, Nikto 05:30-05:31 EDT
Report date	23 October 2026
Report version	2.0 (detailed edition; supersedes v1.0 of 22 October 2026)
Tools used	Nmap 7.95; Nikto 2.5.0; Nuclei v3.11.1 (templates cloned manually); xsltproc; ping
Assessment scope	Authorised lab assessment of the Metasploitable test host only. Network-based, unauthenticated, no exploitation.
Classification	Confidential - lab and training use. Do not generalise to production systems.
Result at a glance	38 findings: 6 Critical, 14 High, 10 Medium, 8 Low. 30 open TCP ports. Nuclei: 59 results.

Document control

Version	Date	Author	Summary of change
1.0	22 Oct 2026	Oluwatosin Olajubu	Initial report from Nmap and Nikto. Nuclei recorded as inconclusive because templates could not be downloaded. 10 register entries.
2.0	23 Oct 2026	Oluwatosin Olajubu	Detailed edition. Nuclei scan completed after manual template clone and 59 results incorporated; register expanded to 38 findings with likelihood x impact scoring, framework mapping, evidence, owners and SLAs; appendices added.

Table 1: *Document control and revision history*

Contents

1. Executive Summary 4
- 1.1 Overview 4
- 1.2 Key findings and risks 4
- 1.3 Decisions requested from management 5
- 1.4 Recommended actions 5

2. Scope, Objectives and Methodology 6
- 2.1 Scope and authorisation 6
- 2.2 Objectives 6
- 2.3 Tools and commands 6
- 2.4 Assessment timeline 6
- 2.5 Risk rating methodology 7
- 2.6 Evidence confidence levels 8

3. Asset Profile and Attack Surface 9
- 3.1 Host profile 9
- 3.2 Open TCP port inventory 9

4. Summary of Results 11
- 4.1 All findings at a glance 11
- 4.2 Heat map 12
- 4.3 Scanner output overview 12
- 4.4 Where the assessed rating differs from the scanner severity 13

5. Risk Assessment Register 14
- 5.1 Register (lab format) 14
- 5.2 Compliance violation and control mapping 17
- 5.3 Recommended actions, owners and target dates 19

6. Detailed Findings 23
- 6.1 Critical findings (Priority 1, fix within 7 days) 23
- 6.2 High findings (Priority 2, fix within 30 days) 26
- 6.3 Medium findings (Priority 3, fix within 90 days) 35
- 6.4 Low findings (Priority 4, fix within 180 days) 41

7. Compliance and GRC Interpretation 46
- 7.1 Lab question: why is knowing which ports are open a compliance issue? 46
- 7.2 Control themes and management implications 46
- 7.3 Framework numbering used and the lab brief 47
- 7.4 Scope caution for PCI DSS 47

8. Remediation Roadmap 48
- 8.1 Governance and process recommendations 48
- 8.2 Retest plan and success measures 48
- 8.3 Residual risk statement 49

9. Limitations and Evidence Notes 50
- 9.1 Evidence inventory 50
- 9.2 Statements about interpretation 51

10. Conclusion 51

11. Sources and References 51

Appendix A. Nuclei Results (all results) 52

Appendix B. Nikto Results (27 items) 55

Appendix C. Selected Nmap Script Output 57

Appendix D. Glossary 59

List of tables

Table 1: Document control and revision history 1
Table 2: Key findings for management attention 4
Table 3: Tools, versions, commands and output files 6
Table 4: Assessment timeline (Kali system time, EDT / GMT-4) 6
Table 5: Likelihood and impact scales 7
Table 6: Rating thresholds, lab mapping, priority and remediation SLA 7
Table 7: Evidence confidence labels used in the findings 8
Table 8: Host profile from ping, Nmap and the target console 9
Table 9: Open TCP ports, services and related findings (Nmap -sV -sC -O -p-) 9
Table 10: Register summary: all findings sorted by risk score 11
Table 11: Raw results by tool 12
Table 12: Scanner severity compared with assessed rating 13
Table 13: Risk assessment register: scoring, reference and business impact 14
Table 14: Suggested control mapping by finding (CIS v8, NIST CSF 2.0, ISO/IEC 27001:2022, PCI DSS v4.0, OWASP Top 10 2021) 17
Table 15: Recommended actions with suggested owner and target date 19
Table 16: Control themes, related findings and implications 46
Table 17: Lab-brief references and current equivalents 47
Table 18: Phased remediation plan 48
Table 19: Success measures for the retest 49
Table 20: Assessment limitations 50
Table 21: Evidence files 50
Table 22: Complete Nuclei output with severity and mapped finding 52
Table 23: Complete Nikto output with category and mapped finding 55
Table 24: Terms and abbreviations 59

List of figures

Figure 1: Assessed findings by inherent risk rating 4
Figure 2: Open TCP ports grouped by the highest-rated finding linked to each port 10
Figure 3: Heat map of findings by likelihood and impact (cell value = number of findings) 12
Figure 4: Nuclei results by scanner severity label 13

1. Executive Summary

To	IT Management
From	GRC Audit Team
Date	23 October 2026
Subject	High-Risk Findings on Development Server 'metasploitable' (192.168.164.129)

1.1 Overview

A vulnerability assessment of the internal development server 'metasploitable' (192.168.164.129) found **38 findings: 6 Critical, 14 High, 10 Medium and 8 Low**. The evidence comes from three tools: an Nmap full-port scan (30 open TCP ports on a host with no network filtering), a Nikto web-server scan (27 items) and a Nuclei scan (59 results: 4 critical, 18 high, 2 medium, 2 low, 33 informational).

The server poses an immediate and high risk to information assets. It is not aligned with several key control expectations based on the CIS Controls (secure configuration, vulnerability management, access control and protection of data in transit). It is an intentionally vulnerable training machine, so the results must not be generalised to production systems; they show what an unmanaged, unhardened development server looks like in a risk register.

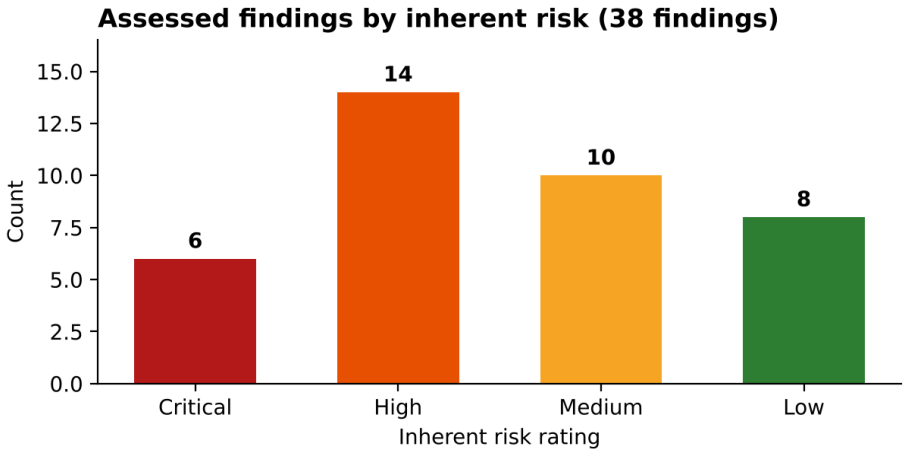


Figure 1: *Assessed findings by inherent risk rating*

1.2 Key findings and risks

Table 2: *Key findings for management attention*

Rating	Theme	What was found and why it matters	Findings
Critical	**Remote system compromise**	The FTP service contains a known backdoor (CVE-2011-2523) that Nuclei detected on TCP/6200, and Nmap found an unauthenticated root shell on TCP/1524. Either gives an attacker full control without a password. Breaches the vulnerability and patch management expectation (CIS 7.1, 7.7).	R01, R02
Critical	**Default and empty credentials**	PostgreSQL accepts an empty and the default password for its superuser, and VNC remote desktop accepts weak passwords. Breaches default-account and unique-password controls (CIS 4.7, 5.2).	R03, R06

Rating	Theme	What was found and why it matters	Findings
Critical	**Exposed remote-execution services**	distccd (CVE-2004-2687) and the Tomcat AJP connector (CVE-2020-1938) are reachable from the network.	R04, R05
High	**Data interception**	Telnet, rlogin/rsh/rexec and FTP send credentials in clear text, and the mail server still offers SSLv2. Breaches protection of data in transit (CIS 3.10, 12.6; NIST CSF PR.DS-02).	R08, R09, R10, R18
High	**Obsolete software**	Apache 2.2.8, PHP 5.2.4, Tomcat 5.5, MySQL 5.0, PostgreSQL 8.3, Samba 3.0.20 and a Linux 2.6 kernel are all past end of life (CIS 2.2, 7.4; ISO A.8.8).	R11, R13-R15, R17, R19
High	**Excessive attack surface**	30 listening services and zero filtered ports show that no host firewall or hardening baseline was applied (CIS 4.4, 4.8; NIST CSF PR.PS-01).	R20

1.3 Decisions requested from management

1. **Approve immediate isolation.** Keep the host on an isolated host-only or VLAN network, with no route to production or the internet, until the Priority 1 findings are closed.
2. **Decide to remediate or rebuild.** The operating system and most packages are unsupported. Rebuilding from a hardened baseline is the recommended option; patching in place is not realistic for several components.
3. **Assign owners and accept the SLAs.** Remediation targets: Critical within 7 days, High within 30 days, Medium within 90 days, Low within 180 days of 23 October 2026.
4. **Approve a retest.** Repeat the Nmap, Nikto and Nuclei scans after remediation and record the template version used.

1.4 Recommended actions

1. **Immediate isolation:** remove the server from the network until remediated.
2. **Remediate:** disable the vsftpd backdoor, the bind shell, distccd and AJP; reset PostgreSQL and VNC credentials; apply security patches or replace obsolete components.
3. **Harden:** disable unnecessary services (Telnet, rlogin/rsh/rexec, IRC, DRb, anonymous FTP); apply a default-deny host firewall; enforce strong, unique passwords and remove default accounts.
4. **Process review:** reinforce procedures for deploying systems according to security baselines, register development assets in the inventory with an owner and purpose, and define patch SLAs.

2. Scope, Objectives and Methodology

2.1 Scope and authorisation

The assessment was limited to the supplied Metasploitable lab target at 192.168.164.129, a VMware guest (MAC 00:0C:29:5B:0B:68) that obtained its address by DHCP from 192.168.164.254 (lease renewal in 746 seconds). The scanner was a Kali Linux VM at 192.168.164.128 on the same /24 subnet. The test was an authorised lab exercise set by the course brief. It was network-based and unauthenticated. No exploitation or destructive testing is claimed; no interactive shell was opened.

2.2 Objectives

1. Discover live hosts and identify open ports and services.
2. Enumerate software versions and identify known vulnerabilities.
3. Analyse the findings and map them to common compliance frameworks (NIST, CIS, PCI DSS and others).
4. Assess the risk level of each finding.
5. Document results in a structured, professional format including visual reports.

2.3 Tools and commands

Table 3: *Tools, versions, commands and output files*

Tool	Version	Purpose	Command	Output
ping	iputils	Confirm the host is alive (asset discovery)	`ping -c 4 192.168.164.129`	Screenshot: 4/4 replies, 0% loss, avg 0.810 ms, TTL 64
Nmap	7.95	Port, service, version, script and OS enumeration	`nmap -sV -sC -O -p- -oA evidence/initial_scan 192.168.164.129`	initial_scan.nmap, .xml, .gnmap
xsltproc	libxml 21406 / libxslt 10143	Convert Nmap XML to an HTML report	`xsltproc -o evidence/initial_scan_report.html /usr/share/nmap/nmap.xsl evidence/initial_scan.xml`	initial_scan_report.html (20 KB); PDF and HTML saved from the browser
Nikto	2.5.0	Web server and application checks on TCP/80	`nikto -h http://192.168.164.129 -output evidence/nikto_scan.txt`	nikto_scan.txt (3.4 KB)
Nuclei	v3.11.1	Template-based vulnerability scanning	`nuclei -u http://192.168.164.129 -o evidence/nuclei_scan.txt`	First run: no templates, 0 bytes. Re-run after template clone: 59 results

2.4 Assessment timeline

Table 4: *Assessment timeline (Kali system time, EDT / GMT-4)*

Time (22 Oct 2026)	Activity	Result
Before 04:57	Environment set up: working directory ~/grc-lab1/evidence; tool versions checked; Nuclei installed from the Kali repository (3.11.1-0kali1)	Nmap 7.95, Nikto 2.5.0, Nuclei v3.11.1, xsltproc confirmed
Before 04:57	Target console checked: DHCP bound 192.168.164.129 from 192.168.164.254; eth1 HWaddr 00:0c:29:5b:0b:68; ping from Kali	Host alive; 4 packets sent, 4 received
04:57:27 - 05:00:32	Nmap full TCP scan with version, default scripts and OS detection (184.73 s)	30 open ports; 65,505 closed (reset); host up, latency 0.0011 s
05:18	HTML report generated with xsltproc; viewed in Firefox; PDF and HTML copies saved 05:22-05:23	Report evidence saved
05:30:48 - 05:31:40	Nikto scan of http://192.168.164.129 (52 s, 8,910 requests, 0 errors)	27 items reported

Time (22 Oct 2026)	Activity	Result
05:44 - 05:46	Nuclei first scan: no templates found; update timed out (context deadline exceeded); debug log saved (468 bytes)	nuclei_scan.txt 0 bytes - inconclusive
After 05:46	Troubleshooting: GitHub reachable (HTTP/2 302 to releases/tag/v10.5.0); update with -timeout 30 still produced no templates; template directory empty	Cause: update download failing, not network outage
After 05:46	Workaround: git clone --depth 1 of projectdiscovery/nuclei-templates into ~/nuclei-templates (14,474 files); Nuclei re-run	59 results

2.5 Risk rating methodology

Each finding receives an inherent-risk rating before controls: **Risk score = Likelihood (1-5) x Impact (1-5)**. The ratings are analyst judgements for the lab environment, not CVSS scores. CVSS values, where quoted, are shown separately as an external reference. The same scores, thresholds and SLAs drive the Excel register that accompanies this report.

Table 5: *Likelihood and impact scales*

Score	Likelihood	Impact
1	Rare - not expected; strong barriers	Insignificant - negligible effect
2	Unlikely - needs unusual conditions or skill	Minor - limited information disclosure or minor disruption
3	Possible - depends on configuration or validation	Moderate - moderate data exposure or service degradation
4	Likely - reachable weakness with well-known techniques	Major - major data compromise, serious disruption or privileged access
5	Almost certain - trivially reachable; confirmed or widely automated	Severe - full system compromise; loss of confidentiality, integrity and availability

Table 6: *Rating thresholds, lab mapping, priority and remediation SLA*

Inherent risk	Score range	Lab rating (H/M/L)	Priority	Remediation SLA	Target date (from 23 Oct 2026)	Lab criterion
Critical	20-25	H	P1	7 days	30 Oct 2026	High: easy to exploit, leads to full system compromise
High	12-19	H	P2	30 days	22 Nov 2026	High: easy to exploit, leads to full system compromise
Medium	8-11	M	P3	90 days	21 Jan 2027	Medium: requires some skill, leads to data leakage
Low	1-7	L	P4	180 days	21 Apr 2027	Low: information disclosure, low impact

Thresholds and SLA days are analyst-defined for this lab; they are not taken from the lab brief and can be changed in the Excel register.

2.6 Evidence confidence levels

Table 7: *Evidence confidence labels used in the findings*

Label	Meaning	How it is reported
Confirmed	A scanner test succeeded (for example credentials accepted, anonymous login granted).	Reported as a fact observed on the host.
Detected by template	An active Nuclei template matched (for example CVE-2011-2523 on TCP/6200).	Treated as confirmed for lab purposes; manual confirmation recommended.
Observed	A service, banner, configuration or script output was seen by Nmap or Nikto.	Reported as observed; exploitability is not claimed.

Label	Meaning	How it is reported
Version-based	A CVE was flagged only because the version string matches.	Reported as potential; validate the installed build before treating as exploitable.
Unverified	A scanner message that may be a false positive.	Rated conservatively and listed for manual review.

3. Asset Profile and Attack Surface

Asset discovery is the foundation of risk management: a host and its services cannot be protected, patched or assessed if they are not known (NIST CSF 2.0 ID.AM-01; CIS Control 1). The lab brief refers to the older NIST CSF 1.1 label ID.AM-1.

3.1 Host profile

Table 8: *Host profile from ping, Nmap and the target console*

IP address	192.168.164.129 (IPv4); IPv6 link-local fe80::20c:29ff:fe5b:b68/64
MAC address	00:0C:29:5B:0B:68 (VMware)
Host / domain names	metasploitable; domain localdomain; FQDN metasploitable.localdomain; NetBIOS name METASPLOITABLE; workgroup WORKGROUP
Operating system	Linux 2.6.9 - 2.6.33 (Nmap OS match 100%); Samba reports "Unix (Samba 3.0.20-Debian)"; package banners indicate a very old Ubuntu release
Network reachability	Ping: 4 sent, 4 received, 0% loss, rtt min/avg/max 0.704/0.810/0.949 ms, TTL 64. Nmap latency 0.0011 s
Scan result	65,535 TCP ports scanned; 30 open; 65,505 closed (reset); 0 filtered
Clock (Nmap clock-skew)	mean 1h00m05s, deviation 2h00m00s, median 4s relative to the scanner
Scanner	Kali Linux 192.168.164.128/24, MAC 00:0c:29:fd:c8:54

3.2 Open TCP port inventory

The table below lists all 30 open ports found by Nmap with the product and version reported, the key script output and the register findings each port supports. A single port can support several findings.

Table 9: *Open TCP ports, services and related findings (Nmap -sV -sC -O -p-)*

Port	Service	Product / version	Key output	Findings
21/tcp	ftp	vsftpd 2.3.4	Anonymous login allowed (230); cleartext control/data	R01, R10
22/tcp	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)	Host keys: 1024-bit DSA, 2048-bit RSA	R26
23/tcp	telnet	Linux telnetd	Cleartext remote login	R08
25/tcp	smtp	Postfix smtpd	SSLv2 supported; VRFY/ETRN; certificate expired 2010-04-16	R18, R31, R32
53/tcp	domain	ISC BIND 9.4.2	bind.version 9.4.2	R27
80/tcp	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)	Title: Metasploitable2 - Linux; PHP 5.2.4	R13, R14, R22-R25, R33-R35
111/tcp	rpcbind	RPC #100000 v2	rpcinfo lists nfs, mountd, nlockmgr, status	R21, R38
139/tcp	netbios-ssn	Samba smbd 3.X - 4.X (WORKGROUP)	SMB over NetBIOS	R12
445/tcp	netbios-ssn	Samba smbd 3.0.20-Debian (WORKGROUP)	Guest account; message signing disabled; SMBv1	R11, R12
512/tcp	exec	netkit-rsh rexecd	r-service	R09
513/tcp	login?	(unidentified)	r-service (rlogin)	R09
514/tcp	shell	Netkit rshd	r-service	R09
1099/tcp	java-rmi	GNU Classpath grmiregistry	RMI registry	R29
1524/tcp	bindshell	Metasploitable root shell	Unauthenticated root shell	R02
2049/tcp	nfs	RPC #100003 v2-4	NFS exports not enumerated	R21

Port	Service	Product / version	Key output	Findings
2121/tcp	ftp	ProFTPD 1.3.1	Second FTP service	R28
3306/tcp	mysql	MySQL 5.0.51a-3ubuntu5	Protocol 10; thread ID 8	R15
3632/tcp	distccd	distccd v1 ((GNU) 4.2.4 Ubuntu 4.2.4-1ubuntu4)	Remote compile daemon	R05
5432/tcp	postgresql	PostgreSQL DB 8.3.0 - 8.3.7	Empty/default credentials; certificate expired	R03, R15, R31
5900/tcp	vnc	VNC (protocol 3.3)	Security type VNC Authentication (2)	R06
6000/tcp	X11	(access denied)	X server listener	R37
6667/tcp	irc	UnrealIRCd 3.2.8.1	irc-info: Unreal3.2.8.1	R07
6697/tcp	irc	UnrealIRCd 3.2.8.1	irc-info: Unreal3.2.8.1	R07
8009/tcp	ajp13	Apache Jserv (Protocol v1.3)	Ghostcat (CVE-2020-1938)	R04
8180/tcp	http	Apache Tomcat/Coyote JSP engine 1.1	Title: Apache Tomcat/5.5	R17
8787/tcp	drb	Ruby DRb RMI (Ruby 1.8)	path /usr/lib/ruby/1.8/drb	R16
54313/tcp	mountd	RPC #100005 v1-3	RPC helper	R21
54570/tcp	status	RPC #100024 v1	RPC helper	R21
54727/tcp	nlockmgr	RPC #100021 v1-4	RPC helper	R21
59365/tcp	java-rmi	GNU Classpath grmiregistry	RMI registry	R29

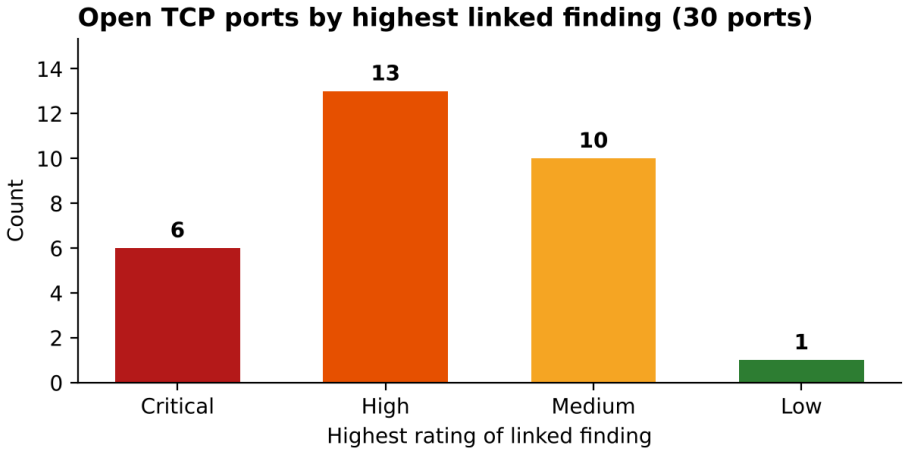


Figure 2: *Open TCP ports grouped by the highest-rated finding linked to each port*

29 of the 30 open ports support at least one finding rated Medium or higher; only TCP/6000 (X11, access denied) is linked solely to a Low finding.

4. Summary of Results

4.1 All findings at a glance

Table 10: *Register summary: all findings sorted by risk score*

ID	Finding	Port	Score	Inherent risk	Lab	Priority
R01	vsftpd 2.3.4 backdoor detected	TCP/21 (backdoor shell TCP/6200)	25	**Critical**	H	P1
R02	Bind shell identified as 'Metasploitable root shell'	TCP/1524	25	**Critical**	H	P1
R03	PostgreSQL accessible with empty and default credentials	TCP/5432	20	**Critical**	H	P1
R04	Apache JServ (AJP) 'Ghostcat' vulnerability	TCP/8009	20	**Critical**	H	P1
R05	distccd remote command execution	TCP/3632	20	**Critical**	H	P1
R06	VNC remote desktop with weak password and weak protocol	TCP/5900	20	**Critical**	H	P1
R07	UnrealIRCd 3.2.8.1 (release known to have been trojaned)	TCP/6667, 6697	15	**High**	H	P2
R08	Telnet service exposed (cleartext remote login)	TCP/23	16	**High**	H	P2
R09	Legacy r-services exposed (rexec, rlogin, rsh)	TCP/512, 513, 514	16	**High**	H	P2
R10	Anonymous FTP login and weak FTP credentials	TCP/21	15	**High**	H	P2
R11	Samba 3.0.20 flagged for CVE-2026-4480 (version-based)	TCP/445	15	**High**	H	P2
R12	SMB weaknesses: SMBv1, guest access and signing disabled	TCP/139, 445 (UDP/137)	12	**High**	H	P2
R13	PHP-CGI argument injection	TCP/80	16	**High**	H	P2
R14	End-of-life web stack: Apache 2.2.8 and PHP 5.2.4	TCP/80	16	**High**	H	P2
R15	Legacy database services exposed to the network	TCP/3306, 5432	16	**High**	H	P2
R16	Ruby DRb (distributed Ruby) service exposed	TCP/8787	16	**High**	H	P2
R17	End-of-life Apache Tomcat 5.5 application server	TCP/8180	16	**High**	H	P2
R18	SSLv2 and weak ciphers supported by SMTP service	TCP/25	12	**High**	H	P2
R19	Unsupported legacy operating system	Host	16	**High**	H	P2
R20	Excessive attack surface and no network filtering	30 open TCP ports	15	**High**	H	P2
R21	NFS and RPC portmapper services exposed	TCP/111, 2049, 54313, 54570, 54727 (UDP/111)	9	**Medium**	M	P3
R22	phpMyAdmin administration interface exposed	TCP/80	9	**Medium**	M	P3
R23	phpinfo() test script exposed	TCP/80	8	**Medium**	M	P3
R24	Directory indexing and browsable documentation paths	TCP/80	8	**Medium**	M	P3
R25	Possible credential file '#wp-config.php#' reported	TCP/80	8	**Medium**	M	P3
R26	Legacy OpenSSH 4.7p1 with 1024-bit DSA host key	TCP/22	9	**Medium**	M	P3
R27	Legacy ISC BIND 9.4.2 DNS service	TCP/53	9	**Medium**	M	P3
R28	Legacy ProFTPD 1.3.1 on alternate FTP port	TCP/2121	9	**Medium**	M	P3
R29	Java RMI registry services exposed	TCP/1099, 59365	9	**Medium**	M	P3
R30	Additional vsftpd CVEs flagged by version match	TCP/21	9	**Medium**	M	P3
R31	Expired TLS certificates on SMTP and PostgreSQL	TCP/25, 5432	6	**Low**	L	P4
R32	SMTP user enumeration commands enabled (VRFY, ETRN)	TCP/25	6	**Low**	L	P4
R33	HTTP TRACE method enabled	TCP/80	6	**Low**	L	P4
R34	Missing HTTP security response headers	TCP/80	6	**Low**	L	P4
R35	Information leakage through headers, ETag and error behaviour	TCP/80	6	**Low**	L	P4
R36	Large clock skew relative to scanner	Host	4	**Low**	L	P4
R37	X11 service listening	TCP/6000	6	**Low**	L	P4

ID	Finding	Port	Score	Inherent risk	Lab	Priority
R38	NetBIOS and RPC information disclosure	UDP/137, UDP/111	6	Low	L	P4

4.2 Heat map

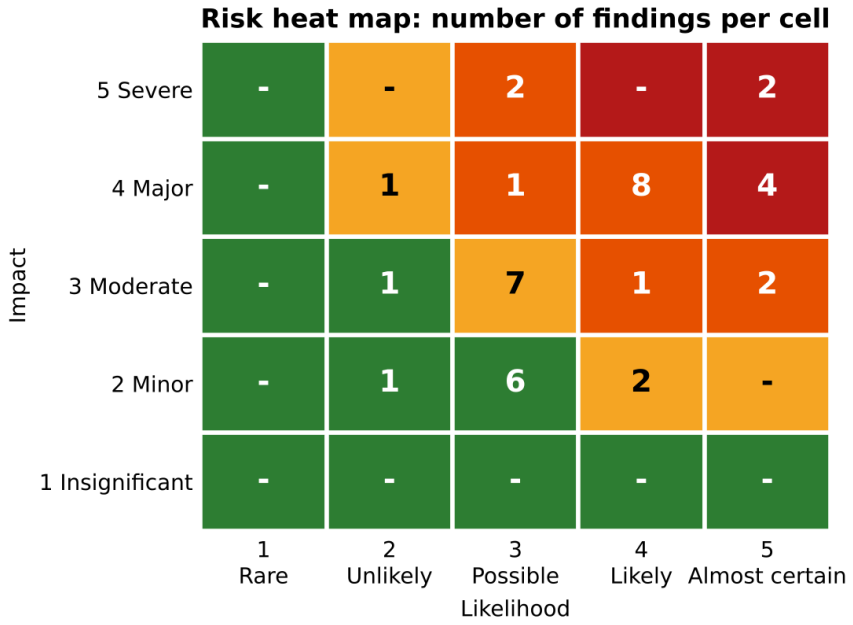


Figure 3: *Heat map of findings by likelihood and impact (cell value = number of findings)*

Most findings cluster at likelihood 4-5 and impact 3-4. Every Critical finding sits in the top-right cells because the weakness is reachable on the network, requires no credentials or only default ones, and gives privileged access.

4.3 Scanner output overview

Table 11: *Raw results by tool*

Tool	Raw results	Breakdown	Mapped to findings
Nmap	30 open ports, script output for 14 ports	ftp-anon, sslv2, ssl-cert, smb-security-mode, vnc-info, irc-info, mysql-info, rpcinfo, ssh-hostkey, dns-nsid, http-title, clock-skew, nbstat	R01-R03, R06-R10, R12, R15-R21, R26-R29, R31, R36-R38
Nikto	27 items	Missing headers 2; outdated server 1; information disclosure 8; directory indexing 5; admin interface 5; other 6 (see Appendix B)	R14, R22-R25, R33-R35
Nuclei	59 results	Critical 4; High 18; Medium 2; Low 2; Info 33 (see Appendix A)	R01, R03-R06, R10-R15, R21-R23, R26, R30, R32-R35, R38

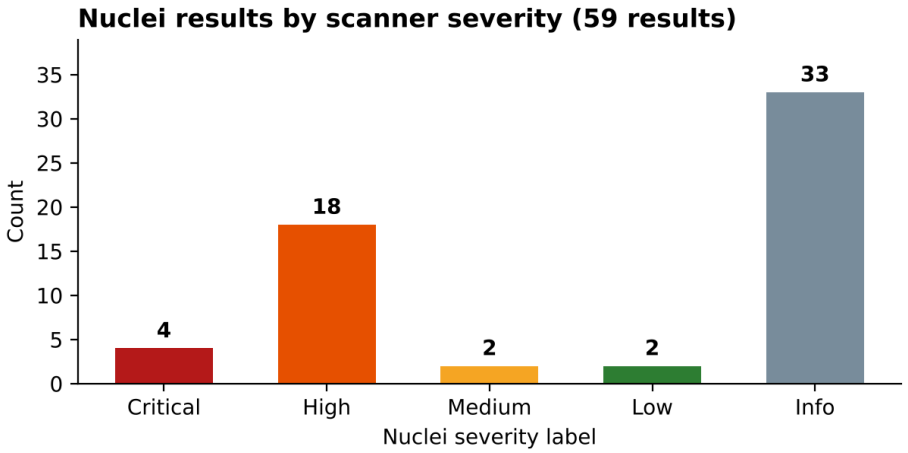


Figure 4: *Nuclei results by scanner severity label*

4.4 Where the assessed rating differs from the scanner severity

Scanner severity labels are inputs, not conclusions. The analyst rating takes exploitability, evidence quality and business context into account. The table below records every case where the rating differs.

Table 12: *Scanner severity compared with assessed rating*

Finding	Scanner severity	Assessed rating	Reason
R05 distccd (CVE-2004-2687)	High	Critical	The service design allows unauthenticated remote command execution for any permitted client.
R11 Samba (CVE-2026-4480)	Critical	High	Version-based match; exploitation depends on the print command configuration and has high attack complexity (CVSS 3.1 AC:H).
R10 FTP weak credentials (8 results)	High x 8	High (one finding)	All eight use the anonymous account "ftp"; they most likely reflect anonymous access accepting any password, so they are counted once.
R30 vsftpd CVE-2021-30047	High	Medium	NVD lists only vsftpd 3.0.3 as affected; the 2.3.4 match is probably a false positive. CVE-2015-1419 (medium) is plausible.
R04 Tomcat AJP (CVE-2020-1938)	Critical	Critical (confirm)	Rating kept because an exposed, unsupported AJP connector is unsafe, but NVD does not list Tomcat 5.5 so manual confirmation is advised.
R12 SMB hardening	Info	High	SMB 1.0 only, guest sessions and signing disabled together create a serious exposure.
R14 End-of-life web stack	Info	High	End-of-life software cannot be patched, which increases the likelihood of every other web finding.
R25 #wp-config.php#	n/a (Nikto message)	Medium	The message is generic and may be a false positive; raise to High if the file exists.

5. Risk Assessment Register

Ratings are preliminary inherent-risk judgements for the lab environment, based on observed exposure and potential business consequence. They are not CVSS scores. Revisit the ratings after validation and after considering the system's business context, compensating controls and exploitability. The columns follow the lab brief (Finding, Affected Service, CVE/Reference, Inherent Risk, Compliance Violation, Business Impact) with scoring and priority added.

5.1 Register (lab format)

Table 13: *Risk assessment register: scoring, reference and business impact*

ID	Finding	Affected service	CVE / reference	Likelihood	Impact	Score	Inherent risk	Lab (H/M/L)	Priority	Business impact
R01	vsftpd 2.3.4 backdoor detected	TCP/21 (backdoor shell TCP/6200) FTP - vsftpd 2.3.4	CVE-2011-2523	5 - Almost certain	5 - Severe	25	**Critical**	H	P1	Unauthenticated remote root-level command execution leading to full host compromise, data theft, and use of the host as a pivot point.
R02	Bind shell identified as 'Metasploitable root shell'	TCP/1524 bindshell	Nmap service identification (no CVE)	5 - Almost certain	5 - Severe	25	**Critical**	H	P1	Direct, unauthenticated privileged access to the operating system; complete loss of confidentiality, integrity and availability.
R03	PostgreSQL accessible with empty and default credentials	TCP/5432 PostgreSQL 8.3.0 - 8.3.7	Nuclei: pgsql-empty-password; postgres-default-logins; pgsql-default-db	5 - Almost certain	4 - Major	20	**Critical**	H	P1	Full read/write access to all databases; possible server-side file access and command execution through superuser features; data breach or tampering.
R04	Apache JServ (AJP) 'Ghostcat' vulnerability	TCP/8009 Apache Jserv AJP13 (Tomcat 5.5 on TCP/8180)	CVE-2020-1938	5 - Almost certain	4 - Major	20	**Critical**	H	P1	Disclosure of application source and configuration (including credentials) and possible remote code execution.
R05	distccd remote command execution	TCP/3632 distccd v1 (GNU 4.2.4)	CVE-2004-2687	5 - Almost certain	4 - Major	20	**Critical**	H	P1	Unauthenticated remote command execution as the daemon user and a stepping stone to privilege escalation.
R06	VNC remote desktop with weak password and weak protocol	TCP/5900 VNC (RFB 003.003)	Nuclei: vnc-default-login; vnc-service-detect	5 - Almost certain	4 - Major	20	**Critical**	H	P1	Interactive desktop control of the host, enabling full compromise, credential capture and tampering.
R07	UnrealIRCd 3.2.8.1 (release known to have been trojaned)	TCP/6667, 6697 UnrealIRCd 3.2.8.1	CVE-2010-2075 (applicability to validate)	3 - Possible	5 - Severe	15	**High**	H	P2	If trojaned: unauthenticated remote command execution. Otherwise: an unnecessary, outdated chat service.
R08	Telnet service exposed (cleartext remote login)	TCP/23 Linux telnetd	No CVE (insecure protocol)	4 - Likely	4 - Major	16	**High**	H	P2	Credential and session interception on any shared network path, leading to unauthorised access.
R09	Legacy r-services exposed (rexec, rlogin, rsh)	TCP/512, 513, 514 netkit-rsh rexecd; login; Netkit rshd	No CVE (insecure protocols)	4 - Likely	4 - Major	16	**High**	H	P2	Unauthorised command execution or login through trusted-host abuse and credential interception.
R10	Anonymous FTP login and weak FTP credentials	TCP/21 FTP - vsftpd 2.3.4	Nmap ftp-anon; Nuclei ftp-anonymous-login; ftp-weak-credentials	5 - Almost certain	3 - Moderate	15	**High**	H	P2	Unauthorised file access or upload, service abuse, and interception of any credentials or data sent over FTP.

ID	Finding	Affected service	CVE / reference	Likelihood	Impact	Score	Inherent risk	Lab (H/M/L)	Priority	Business impact
R11	Samba 3.0.20 flagged for CVE-2026-4480 (version-based)	TCP/445 Samba smbd 3.0.20-Debian	CVE-2026-4480	3 - Possible	5 - Severe	15	**High**	H	P2	Potential remote code execution on the file server.
R12	SMB weaknesses: SMBv1, guest access and signing disabled	TCP/139, 445 (UDP/137) Samba smbd 3.0.20-Debian	Nmap smb-security-mode; Nuclei smb-v1-supported	4 - Likely	3 - Moderate	12	**High**	H	P2	Unauthorised share access, information disclosure and man-in-the-middle manipulation of SMB traffic.
R13	PHP-CGI argument injection	TCP/80 Apache httpd 2.2.8 / PHP 5.2.4	CVE-2012-1823	4 - Likely	4 - Major	16	**High**	H	P2	Source-code disclosure and potential remote code execution through the web server.
R14	End-of-life web stack: Apache 2.2.8 and PHP 5.2.4	TCP/80 Apache/2.2.8 (Ubuntu) DAV/2; PHP/5.2.4-2ubuntu5.10	Nikto outdated-version notice; Nuclei apache-httpd-eol and php-eol	4 - Likely	4 - Major	16	**High**	H	P2	Web compromise, information disclosure or denial of service; non-compliance with patching expectations.
R15	Legacy database services exposed to the network	TCP/3306, 5432 MySQL 5.0.51a-3ubuntu5; PostgreSQL 8.3.0 - 8.3.7	Nmap version banners; Nuclei pgsql-detect	4 - Likely	4 - Major	16	**High**	H	P2	Unauthorised data access, tampering or disruption if authentication or patching is weak (see R03).
R16	Ruby DRb (distributed Ruby) service exposed	TCP/8787 Ruby DRb RMI (Ruby 1.8)	Nmap service identification	4 - Likely	4 - Major	16	**High**	H	P2	Potential remote code execution on the host.
R17	End-of-life Apache Tomcat 5.5 application server	TCP/8180 Apache Tomcat/Coyote JSP engine 1.1 (Tomcat 5.5)	Nmap http-title 'Apache Tomcat/5.5'	4 - Likely	4 - Major	16	**High**	H	P2	Application compromise, credential exposure and possible code deployment through management interfaces.
R18	SSLv2 and weak ciphers supported by SMTP service	TCP/25 Postfix smtpd	Nmap sslv2 script; obsolete protocol (no CVE)	3 - Possible	4 - Major	12	**High**	H	P2	Weakened confidentiality and integrity of mail transport and possible downgrade attacks.
R19	Unsupported legacy operating system	Host Linux 2.6.9 - 2.6.33	Nmap OS detection	4 - Likely	4 - Major	16	**High**	H	P2	Persistent exposure to known kernel and library vulnerabilities, including local privilege escalation.
R20	Excessive attack surface and no network filtering	30 open TCP ports Host-wide	Nmap full TCP scan	5 - Almost certain	3 - Moderate	15	**High**	H	P2	Large attack surface that multiplies the likelihood that at least one weakness is exploited.
R21	NFS and RPC portmapper services exposed	TCP/111, 2049, 54313, 54570, 54727 (UDP/111) rpcbind; nfs 2-4; mountd; nlockmgr; status	Nmap rpcinfo; Nuclei nfs-v3-exposed, rpc-udp-detect	3 - Possible	3 - Moderate	9	**Medium**	M	P3	Possible unauthorised file read/write if exports are open.
R22	phpMyAdmin administration interface exposed	TCP/80 phpMyAdmin (under /phpMyAdmin/)	Nikto; Nuclei phpmyadmin-panel	3 - Possible	3 - Moderate	9	**Medium**	M	P3	Database takeover if weak credentials or vulnerabilities exist.
R23	phpinfo() test script exposed	TCP/80 /phpinfo.php	CWE-552; Nuclei phpinfo-files	4 - Likely	2 - Minor	8	**Medium**	M	P3	Reconnaissance data that makes targeted attacks easier.
R24	Directory indexing and browsable documentation paths	TCP/80 /doc/, /test/, /icons/	CVE-1999-0678 (/doc/); Nikto	4 - Likely	2 - Minor	8	**Medium**	M	P3	Information disclosure and discovery of further attack targets.
R25	Possible credential file '#wp-config.php#' reported	TCP/80 /#wp-config.php#	Nikto finding	2 - Unlikely	4 - Major	8	**Medium**	M	P3	If confirmed: disclosure of database credentials and takeover of the application's data.
R26	Legacy OpenSSH 4.7p1 with 1024-bit DSA host key	TCP/22 OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)	Nmap ssh-hostkey; Nuclei openssh-detect	3 - Possible	3 - Moderate	9	**Medium**	M	P3	Weak cryptographic assurance and exposure to known OpenSSH flaws.

ID	Finding	Affected service	CVE / reference	Likelihood	Impact	Score	Inherent risk	Lab (H/M/L)	Priority	Business impact
R27	Legacy ISC BIND 9.4.2 DNS service	TCP/53 ISC BIND 9.4.2	Nmap dns-nsid	3 - Possible	3 - Moderate	9	**Medium**	M	P3	Exposure to DNS software flaws and possible abuse as a resolver.
R28	Legacy ProFTPD 1.3.1 on alternate FTP port	TCP/2121 ProFTPD 1.3.1	Nmap -sV	3 - Possible	3 - Moderate	9	**Medium**	M	P3	Cleartext file transfer and exposure to ProFTPD vulnerabilities.
R29	Java RMI registry services exposed	TCP/1099, 59365 GNU Classpath grmiregistry	Nmap -sV	3 - Possible	3 - Moderate	9	**Medium**	M	P3	Potential remote code execution or information disclosure.
R30	Additional vsftpd CVEs flagged by version match	TCP/21 vsftpd 2.3.4	CVE-2015-1419; CVE-2021-30047	3 - Possible	3 - Moderate	9	**Medium**	M	P3	Access-restriction bypass or denial of service of the FTP service.
R31	Expired TLS certificates on SMTP and PostgreSQL	TCP/25, 5432 Certificate CN=ubuntu804-base.localdomain	Nmap ssl-cert; ssl-date	3 - Possible	2 - Minor	6	**Low**	L	P4	Trust failure, certificate warnings that train users to ignore errors, and weakened transport security.
R32	SMTP user enumeration commands enabled (VRFY, ETRN)	TCP/25 Postfix smtpd	Nmap smtp-commands; Nuclei smtp-commands-enum	3 - Possible	2 - Minor	6	**Low**	L	P4	Account discovery that supports password-guessing and phishing.
R33	HTTP TRACE method enabled	TCP/80 Apache httpd 2.2.8	Cross-Site Tracing (OWASP); Nuclei http-trace	3 - Possible	2 - Minor	6	**Low**	L	P4	Low on its own; adds to client-side attack options.
R34	Missing HTTP security response headers	TCP/80 Apache httpd 2.2.8	OWASP Secure Headers; Nuclei http-missing-security-headers	3 - Possible	2 - Minor	6	**Low**	L	P4	Increased exposure of users to client-side attacks.
R35	Information leakage through headers, ETag and error behaviour	TCP/80 Apache httpd 2.2.8 / PHP 5.2.4	CVE-2003-1418; OSVDB-12184; Nuclei apache-mod-negotiation-listing	3 - Possible	2 - Minor	6	**Low**	L	P4	Reconnaissance value only; supports other attacks.
R36	Large clock skew relative to scanner	Host System time	Nmap clock-skew	2 - Unlikely	2 - Minor	4	**Low**	L	P4	Unreliable log timelines for investigations.
R37	X11 service listening	TCP/6000 X11	Nmap -sV	2 - Unlikely	3 - Moderate	6	**Low**	L	P4	Potential screen/keystroke exposure if access control is relaxed.
R38	NetBIOS and RPC information disclosure	UDP/137, UDP/111 NetBIOS name service; RPC portmapper	Nuclei netbios-udp-detect, rpc-udp-detect; Nmap nbstat, smb-os-discovery	3 - Possible	2 - Minor	6	**Low**	L	P4	Reconnaissance support.

5.2 Compliance violation and control mapping

Mappings are suggested control alignments, not proof of formal non-compliance. A formal conclusion needs confirmation of the applicable framework, system scope, control requirements and evidence of control operation. PCI DSS applies only if the server is within the cardholder-data environment.

Table 14: *Suggested control mapping by finding (CIS v8, NIST CSF 2.0, ISO/IEC 27001:2022, PCI DSS v4.0, OWASP Top 10 2021)*

ID	Finding	CIS Controls v8	NIST CSF 2.0	ISO/IEC 27001:2022 Annex A	PCI DSS v4.0 (if in scope)	OWASP Top 10 2021
R01	vsftpd 2.3.4 backdoor detected	CIS 7.1, 7.4, 7.7	ID.RA-01; PR.PS-02	A.8.8	Req. 6.3.1, 6.3.3	A06:2021 Vulnerable and Outdated Components

ID	Finding	CIS Controls v8	NIST CSF 2.0	ISO/IEC 27001:2022 Annex A	PCI DSS v4.0 (if in scope)	OWASP Top 10 2021
R02	Bind shell identified as 'Metasploitable root shell'	CIS 4.1, 4.8	PR.PS-01	A.8.9	Req. 2.2.4	A05:2021 Security Misconfiguration
R03	PostgreSQL accessible with empty and default credentials	CIS 4.7, 5.2, 6.1	PR.AA-01; PR.AA-03	A.5.17; A.8.5	Req. 2.2.2, 8.3.1, 8.3.6	A07:2021 Identification and Authentication Failures
R04	Apache JServ (AJP) 'Ghostcat' vulnerability	CIS 7.1, 7.4, 7.7	ID.RA-01; PR.PS-02	A.8.8	Req. 6.3.1, 6.3.3	A06:2021 Vulnerable and Outdated Components
R05	distccd remote command execution	CIS 4.1, 4.8	PR.PS-01	A.8.9	Req. 2.2.4	A05:2021 Security Misconfiguration
R06	VNC remote desktop with weak password and weak protocol	CIS 4.7, 5.2, 6.1	PR.AA-01; PR.AA-03	A.5.17; A.8.5	Req. 2.2.2, 8.3.1, 8.3.6	A07:2021 Identification and Authentication Failures
R07	UnrealIRCd 3.2.8.1 (release known to have been trojaned)	CIS 7.1, 7.4, 7.7	ID.RA-01; PR.PS-02	A.8.8	Req. 6.3.1, 6.3.3	A06:2021 Vulnerable and Outdated Components
R08	Telnet service exposed (cleartext remote login)	CIS 3.10, 12.6	PR.DS-02	A.8.24; A.5.14	Req. 2.2.7, 4.2.1	A02:2021 Cryptographic Failures
R09	Legacy r-services exposed (rexec, rlogin, rsh)	CIS 3.10, 12.6	PR.DS-02	A.8.24; A.5.14	Req. 2.2.7, 4.2.1	A02:2021 Cryptographic Failures
R10	Anonymous FTP login and weak FTP credentials	CIS 4.7, 5.2, 6.1	PR.AA-01; PR.AA-03	A.5.17; A.8.5	Req. 2.2.2, 8.3.1, 8.3.6	A07:2021 Identification and Authentication Failures
R11	Samba 3.0.20 flagged for CVE-2026-4480 (version-based)	CIS 7.1, 7.4, 7.7	ID.RA-01; PR.PS-02	A.8.8	Req. 6.3.1, 6.3.3	A06:2021 Vulnerable and Outdated Components
R12	SMB weaknesses: SMBv1, guest access and signing disabled	CIS 3.3, 6.1, 6.8	PR.AA-05	A.5.15; A.8.3	Req. 7.2	A01:2021 Broken Access Control
R13	PHP-CGI argument injection	CIS 7.1, 7.4, 7.7	ID.RA-01; PR.PS-02	A.8.8	Req. 6.3.1, 6.3.3	A06:2021 Vulnerable and Outdated Components
R14	End-of-life web stack: Apache 2.2.8 and PHP 5.2.4	CIS 2.2, 7.4, 7.7	PR.PS-02; ID.RA-01	A.8.8; A.8.19	Req. 6.3.3	A06:2021 Vulnerable and Outdated Components
R15	Legacy database services exposed to the network	CIS 2.2, 7.4, 7.7	PR.PS-02; ID.RA-01	A.8.8; A.8.19	Req. 6.3.3	A06:2021 Vulnerable and Outdated Components
R16	Ruby DRb (distributed Ruby) service exposed	CIS 4.1, 4.8	PR.PS-01	A.8.9	Req. 2.2.4	A05:2021 Security Misconfiguration
R17	End-of-life Apache Tomcat 5.5 application server	CIS 2.2, 7.4, 7.7	PR.PS-02; ID.RA-01	A.8.8; A.8.19	Req. 6.3.3	A06:2021 Vulnerable and Outdated Components
R18	SSLv2 and weak ciphers supported by SMTP service	CIS 3.10, 12.6	PR.DS-02	A.8.24; A.5.14	Req. 2.2.7, 4.2.1	A02:2021 Cryptographic Failures
R19	Unsupported legacy operating system	CIS 2.2, 7.4, 7.7	PR.PS-02; ID.RA-01	A.8.8; A.8.19	Req. 6.3.3	A06:2021 Vulnerable and Outdated Components
R20	Excessive attack surface and no network filtering	CIS 4.4, 12.2, 13.4	PR.IR-01	A.8.20; A.8.22	Req. 1.3, 1.4	A05:2021 Security Misconfiguration
R21	NFS and RPC portmapper services exposed	CIS 3.3, 6.1, 6.8	PR.AA-05	A.5.15; A.8.3	Req. 7.2	A01:2021 Broken Access Control
R22	phpMyAdmin administration interface exposed	CIS 3.3, 6.1, 6.8	PR.AA-05	A.5.15; A.8.3	Req. 7.2	A01:2021 Broken Access Control
R23	phpinfo() test script exposed	CIS 16.7, 4.1	PR.PS-01	A.8.9	Req. 6.2.4	A05:2021 Security Misconfiguration (CWE-200)
R24	Directory indexing and browsable documentation paths	CIS 16.7	PR.PS-01	A.8.9; A.8.26	Req. 6.2.4	A05:2021 Security Misconfiguration
R25	Possible credential file '#wp-config.php#' reported	CIS 16.7, 4.1	PR.PS-01	A.8.9	Req. 6.2.4	A05:2021 Security Misconfiguration (CWE-200)
R26	Legacy OpenSSH 4.7p1 with 1024-bit DSA host key	CIS 2.2, 7.4, 7.7	PR.PS-02; ID.RA-01	A.8.8; A.8.19	Req. 6.3.3	A06:2021 Vulnerable and Outdated Components
R27	Legacy ISC BIND 9.4.2 DNS service	CIS 2.2, 7.4, 7.7	PR.PS-02; ID.RA-01	A.8.8; A.8.19	Req. 6.3.3	A06:2021 Vulnerable and Outdated Components
R28	Legacy ProFTPD 1.3.1 on alternate FTP port	CIS 2.2, 7.4, 7.7	PR.PS-02; ID.RA-01	A.8.8; A.8.19	Req. 6.3.3	A06:2021 Vulnerable and Outdated Components
R29	Java RMI registry services exposed	CIS 4.1, 4.8	PR.PS-01	A.8.9	Req. 2.2.4	A05:2021 Security Misconfiguration
R30	Additional vsftpd CVEs flagged by version match	CIS 7.1, 7.4, 7.7	ID.RA-01; PR.PS-02	A.8.8	Req. 6.3.1, 6.3.3	A06:2021 Vulnerable and Outdated Components

ID	Finding	CIS Controls v8	NIST CSF 2.0	ISO/IEC 27001:2022 Annex A	PCI DSS v4.0 (if in scope)	OWASP Top 10 2021
R31	Expired TLS certificates on SMTP and PostgreSQL	CIS 3.10, 12.6	PR.DS-02	A.8.24; A.5.14	Req. 2.2.7, 4.2.1	A02:2021 Cryptographic Failures
R32	SMTP user enumeration commands enabled (VRFY, ETRN)	CIS 16.7, 4.1	PR.PS-01	A.8.9	Req. 6.2.4	A05:2021 Security Misconfiguration (CWE-200)
R33	HTTP TRACE method enabled	CIS 16.7	PR.PS-01	A.8.9; A.8.26	Req. 6.2.4	A05:2021 Security Misconfiguration
R34	Missing HTTP security response headers	CIS 16.7	PR.PS-01	A.8.9; A.8.26	Req. 6.2.4	A05:2021 Security Misconfiguration
R35	Information leakage through headers, ETag and error behaviour	CIS 16.7, 4.1	PR.PS-01	A.8.9	Req. 6.2.4	A05:2021 Security Misconfiguration (CWE-200)
R36	Large clock skew relative to scanner	CIS 8.4	PR.PS-04	A.8.17	Req. 10.6	n/a
R37	X11 service listening	CIS 4.1, 4.8	PR.PS-01	A.8.9	Req. 2.2.4	A05:2021 Security Misconfiguration
R38	NetBIOS and RPC information disclosure	CIS 16.7, 4.1	PR.PS-01	A.8.9	Req. 6.2.4	A05:2021 Security Misconfiguration (CWE-200)

5.3 Recommended actions, owners and target dates

Table 15: *Recommended actions with suggested owner and target date*

ID	Finding	Priority	Immediate action	Long-term action	Suggested owner	Target date
R01	vsftpd 2.3.4 backdoor detected	P1	Stop and disable vsftpd; isolate the host from other networks; confirm the finding in the lab (connect to TCP/6200 after triggering) only under instructor approval.	Remove the trojaned package; reinstall vsftpd from a trusted, signed repository at a supported version (or use SFTP); rebuild the host if integrity cannot be assured.	System administrator	30 Oct 2026
R02	Bind shell identified as 'Metasploitable root shell'	P1	Identify and kill the listening process; block TCP/1524 at host and network level; keep host isolated.	Investigate how the listener is started (inetd/xinetd, init scripts); remove; add a host firewall default-deny policy; monitor for new listeners.	System administrator	30 Oct 2026
R03	PostgreSQL accessible with empty and default credentials	P1	Set a strong unique password for 'postgres'; restrict listen_addresses and pg_hba.conf to named application hosts; block TCP/5432 at the host firewall.	Enforce scram authentication on a supported PostgreSQL release; remove default accounts; vault credentials; log and alert on superuser logins.	Database administrator	30 Oct 2026
R04	Apache JServ (AJP) 'Ghostcat' vulnerability	P1	Disable the AJP connector or bind it to localhost; block TCP/8009.	Upgrade Tomcat to a supported, patched release; if AJP is needed, require a shared secret and restrict by address.	Application owner	30 Oct 2026
R05	distccd remote command execution	P1	Stop distccd; block TCP/3632.	Do not expose compile services; if needed, use --allow with specific hosts, bind to an internal interface and add network ACLs.	System administrator	30 Oct 2026
R06	VNC remote desktop with weak password and weak protocol	P1	Change the VNC password or stop the service; block TCP/5900 except via an SSH tunnel or VPN.	Replace with an encrypted, MFA-protected remote access method; enforce password policy; monitor remote access.	System administrator	30 Oct 2026
R07	UnrealIRCd 3.2.8.1 (release known to have been trojaned)	P2	Stop the IRC services; block TCP/6667 and 6697.	Remove IRC from the server; if required, install a supported release from a verified source and compare checksums.	System administrator	22 Nov 2026
R08	Telnet service exposed (cleartext remote login)	P2	Disable telnetd; block TCP/23.	Use SSH with key-based authentication for administration; apply the baseline that prohibits cleartext management protocols.	System administrator	22 Nov 2026
R09	Legacy r-services exposed (rexec, rlogin, rsh)	P2	Disable rexecd, rlogind and rshd; block TCP/512-514.	Remove the rsh server packages; use SSH only.	System administrator	22 Nov 2026
R10	Anonymous FTP login and weak FTP credentials	P2	Disable anonymous access unless formally approved; restrict directories and source addresses.	Replace FTP with SFTP or FTPS; apply least-privilege chroot; review the upload directory.	System administrator	22 Nov 2026

ID	Finding	Priority	Immediate action	Long-term action	Suggested owner	Target date
R11	Samba 3.0.20 flagged for CVE-2026-4480 (version-based)	P2	Restrict TCP/139 and 445 to approved clients; review smb.conf for 'print command' and printing shares.	Upgrade Samba to a supported, patched release; disable printing support if not needed.	System administrator	22 Nov 2026
R12	SMB weaknesses: SMBv1, guest access and signing disabled	P2	Disable guest access; require SMB signing; restrict to approved hosts.	Disable SMB1; move to a supported Samba/SMB 3 configuration with encryption.	System administrator	22 Nov 2026
R13	PHP-CGI argument injection	P2	Restrict public access to the web server; disable php-cgi in favour of a module/FPM setup.	Upgrade PHP to a supported version; apply web application firewall rules; include in regular web scans.	Application owner	22 Nov 2026
R14	End-of-life web stack: Apache 2.2.8 and PHP 5.2.4	P2	Restrict web exposure to authorised users; plan immediate upgrade path.	Migrate to supported Apache 2.4.x and PHP 8.x; adopt patch SLAs and automated update monitoring.	Application owner	22 Nov 2026
R15	Legacy database services exposed to the network	P2	Bind databases to localhost or an internal interface; restrict by host firewall.	Upgrade to supported releases; enforce encrypted connections and least-privilege accounts.	Database administrator	22 Nov 2026
R16	Ruby DRb (distributed Ruby) service exposed	P2	Stop the DRb service; block TCP/8787.	Remove unnecessary Ruby services; if needed, bind to localhost and use ACLs.	System administrator	22 Nov 2026
R17	End-of-life Apache Tomcat 5.5 application server	P2	Restrict access to TCP/8180; verify that default manager credentials and sample apps are removed.	Upgrade to a supported Tomcat release; remove sample applications; apply a hardening baseline.	Application owner	22 Nov 2026
R18	SSLv2 and weak ciphers supported by SMTP service	P2	Disable SSLv2 and SSLv3 in the Postfix TLS settings.	Allow only TLS 1.2+ with modern cipher suites; renew certificates (see R31).	Messaging administrator	22 Nov 2026
R19	Unsupported legacy operating system	P2	Keep the host isolated; do not store real data.	Rebuild on a supported OS from a hardened baseline image.	System administrator	22 Nov 2026
R20	Excessive attack surface and no network filtering	P2	Apply a default-deny host firewall and allow only required ports from named sources.	Adopt a secure build baseline (CIS Benchmark) that disables unused services; record the asset in the inventory with an owner and purpose.	Network/security engineer	22 Nov 2026
R21	NFS and RPC portmapper services exposed	P3	Block RPC/NFS from untrusted hosts; review /etc/exports.	Disable NFS where unneeded; otherwise use NFSv4 with Kerberos and strict export lists.	System administrator	21 Jan 2027
R22	phpMyAdmin administration interface exposed	P3	Restrict /phpMyAdmin/ to administrator IPs or remove it.	Upgrade or remove; require MFA or VPN for administrative tools; remove changelog and documentation files.	Application owner	21 Jan 2027
R23	phpinfo() test script exposed	P3	Delete phpinfo.php.	Add a release check that removes diagnostic scripts from deployed environments.	Application owner	21 Jan 2027
R24	Directory indexing and browsable documentation paths	P3	Disable Options Indexes; remove /test/ and default content.	Use a hardened Apache configuration template (CIS Apache Benchmark).	Application owner	21 Jan 2027
R25	Possible credential file '#wp-config.php#' reported	P3	Request the URL manually; if present, remove and rotate the credentials it contains.	Block access to backup and temporary files; scan builds for secrets.	Application owner	21 Jan 2027
R26	Legacy OpenSSH 4.7p1 with 1024-bit DSA host key	P3	Restrict SSH to management hosts.	Upgrade OpenSSH; regenerate host keys (Ed25519 or RSA 3072+); disable password logins where possible.	System administrator	21 Jan 2027
R27	Legacy ISC BIND 9.4.2 DNS service	P3	Disable named if not required, or limit queries to approved clients.	Upgrade to a supported BIND release; hide version; restrict recursion and zone transfers.	Network/security engineer	21 Jan 2027
R28	Legacy ProFTPD 1.3.1 on alternate FTP port	P3	Stop the service or restrict by host firewall.	Remove or replace with SFTP.	System administrator	21 Jan 2027
R29	Java RMI registry services exposed	P3	Block TCP/1099 and 59365 from untrusted hosts.	Disable unneeded RMI services; configure serialization filters and authentication.	Application owner	21 Jan 2027
R30	Additional vsftpd CVEs flagged by version match	P3	Covered by removing vsftpd (see R01).	Upgrade to a supported release.	System administrator	21 Jan 2027
R31	Expired TLS certificates on SMTP and PostgreSQL	P4	Note for remediation; no immediate action beyond isolation.	Issue certificates from an approved CA with managed renewal and inventory.	Messaging / database administrator	21 Apr 2027

ID	Finding	Priority	Immediate action	Long-term action	Suggested owner	Target date
R32	SMTP user enumeration commands enabled (VRFY, ETRN)	P4	Set disable_vrfy_command = yes and restrict ETRN.	Harden mail configuration to a baseline.	Messaging administrator	21 Apr 2027
R33	HTTP TRACE method enabled	P4	Add TraceEnable off.	Include in the web server baseline.	Application owner	21 Apr 2027
R34	Missing HTTP security response headers	P4	Add headers in Apache configuration for the pages that remain in use.	Serve over HTTPS with HSTS and a reviewed CSP.	Application owner	21 Apr 2027
R35	Information leakage through headers, ETag and error behaviour	P4	Set ServerTokens Prod, ExposePHP off, FileETag MTime Size; disable MultiViews.	Harden to a baseline and re-scan.	Application owner	21 Apr 2027
R36	Large clock skew relative to scanner	P4	None beyond note.	Configure NTP and a standard time zone.	System administrator	21 Apr 2027
R37	X11 service listening	P4	Disable remote X11 (-nolisten tcp).	Use SSH X11 forwarding only where needed.	System administrator	21 Apr 2027
R38	NetBIOS and RPC information disclosure	P4	Block UDP/137 and 111 from untrusted hosts.	Disable NetBIOS over TCP/IP where not needed.	Network/security engineer	21 Apr 2027

6. Detailed Findings

Each finding card gives the evidence, description, business impact, control mapping and recommended actions. Findings are grouped by assessed rating and ordered by score. Evidence quotes are taken from the Nmap, Nikto and Nuclei output saved on 22 October 2026.

6.1 Critical findings (Priority 1, fix within 7 days)

R01 vsftpd 2.3.4 backdoor detected

Inherent risk	**Critical | Score 25 (Likelihood 5 Almost certain x Impact 5 Severe) | Lab H | P1**
Affected service	TCP/21 (backdoor shell TCP/6200); FTP - vsftpd 2.3.4
CVE / reference	CVE-2011-2523 CVSS / external severity: 9.8 Critical (CVSS v3.1, NVD); 10.0 (CVSS v2)
Detected by	Nmap; Nuclei | Scanner severity: Critical
Status / validation	Detected by Nuclei template (CVE-2011-2523, matched on TCP/6200); manual confirmation recommended
Evidence	Nmap -sV banner 'vsftpd 2.3.4' on TCP/21. Nuclei template CVE-2011-2523 [tcp] [critical] matched 192.168.164.129:6200.
Description	The vsftpd 2.3.4 source package downloaded between 30 June and 3 July 2011 contained a malicious backdoor (NVD): a login name ending in ':)' opens a root command shell on TCP/6200. The Nuclei template reported a match on that port, so this is stronger evidence than a banner alone.
Business impact	Unauthenticated remote root-level command execution leading to full host compromise, data theft, and use of the host as a pivot point.
Compliance mapping	CIS Controls v8: CIS 7.1, 7.4, 7.7 NIST CSF 2.0: ID.RA-01; PR.PS-02 ISO/IEC 27001:2022: A.8.8 PCI DSS v4.0 (if in scope): Req. 6.3.1, 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Stop and disable vsftpd; isolate the host from other networks; confirm the finding in the lab (connect to TCP/6200 after triggering) only under instructor approval.
Recommended action: long-term	Remove the trojaned package; reinstall vsftpd from a trusted, signed repository at a supported version (or use SFTP); rebuild the host if integrity cannot be assured.
Owner and target	System administrator | SLA 7 days | Target 30 Oct 2026 | Status: Open
Validation note	Template-based detection. Treat as confirmed for lab purposes; document manual confirmation if performed.

R02 Bind shell identified as 'Metasploitable root shell'

Inherent risk	**Critical | Score 25 (Likelihood 5 Almost certain x Impact 5 Severe) | Lab H | P1**
Affected service	TCP/1524; bindshell
CVE / reference	Nmap service identification (no CVE) CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap -sV service identification); no interactive session opened
Evidence	Nmap: '1524/tcp open bindshell Metasploitable root shell'.
Description	A listening service on TCP/1524 is identified by Nmap as a root shell that accepts connections without authentication (a bind shell). Such services are a hallmark of a deliberately planted backdoor.
Business impact	Direct, unauthenticated privileged access to the operating system; complete loss of confidentiality, integrity and availability.

Compliance mapping	CIS Controls v8: CIS 4.1, 4.8 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9 PCI DSS v4.0 (if in scope): Req. 2.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration
Recommended action: immediate	Identify and kill the listening process; block TCP/1524 at host and network level; keep host isolated.
Recommended action: long-term	Investigate how the listener is started (inetd/xinetd, init scripts); remove; add a host firewall default-deny policy; monitor for new listeners.
Owner and target	System administrator | SLA 7 days | Target 30 Oct 2026 | Status: Open
Validation note	Service identity comes from Nmap fingerprinting. Confirm by process inspection on the host.

R03 PostgreSQL accessible with empty and default credentials

Inherent risk	**Critical | Score 20 (Likelihood 5 Almost certain x Impact 4 Major) | Lab H | P1**
Affected service	TCP/5432; PostgreSQL 8.3.0 - 8.3.7
CVE / reference	Nuclei: pgsql-empty-password; postgres-default-logins; pgsql-default-db CVSS / external severity: Not scored
Detected by	Nmap; Nuclei | Scanner severity: Critical
Status / validation	Confirmed by Nuclei credential tests
Evidence	Nuclei [pgsql-empty-password] critical; [postgres-default-logins] high (postgres/postgres); [pgsql-default-db] high x4 (databases 'postgres' and 'template1', password 'postgres' and empty).
Description	The database superuser account 'postgres' accepts an empty password and the well-known default password 'postgres'. The network listener is reachable from the scanning host.
Business impact	Full read/write access to all databases; possible server-side file access and command execution through superuser features; data breach or tampering.
Compliance mapping	CIS Controls v8: CIS 4.7, 5.2, 6.1 NIST CSF 2.0: PR.AA-01; PR.AA-03 ISO/IEC 27001:2022: A.5.17; A.8.5 PCI DSS v4.0 (if in scope): Req. 2.2.2, 8.3.1, 8.3.6 OWASP Top 10 2021: A07:2021 Identification and Authentication Failures
Recommended action: immediate	Set a strong unique password for 'postgres'; restrict listen_addresses and pg_hba.conf to named application hosts; block TCP/5432 at the host firewall.
Recommended action: long-term	Enforce scram authentication on a supported PostgreSQL release; remove default accounts; vault credentials; log and alert on superuser logins.
Owner and target	Database administrator | SLA 7 days | Target 30 Oct 2026 | Status: Open
Validation note	Authentication success was reported by the Nuclei templates.

R04 Apache JServ (AJP) 'Ghostcat' vulnerability

Inherent risk	**Critical | Score 20 (Likelihood 5 Almost certain x Impact 4 Major) | Lab H | P1**
Affected service	TCP/8009; Apache Jserv AJP13 (Tomcat 5.5 on TCP/8180)
CVE / reference	CVE-2020-1938 CVSS / external severity: 9.8 Critical (CVSS v3.1, NVD)
Detected by	Nmap; Nuclei | Scanner severity: Critical
Status / validation	Detected by Nuclei template; NVD does not list Tomcat 5.5 - confirm manually
Evidence	Nuclei [CVE-2020-1938] [tcp] [critical] 192.168.164.129:8009. Nmap: 8009/tcp ajp13 Apache Jserv (Protocol v1.3).

Description	The AJP connector is reachable and was flagged for Ghostcat: Tomcat trusts AJP connections more than HTTP, so anyone who can reach the port can read files from the web application and process files as JSP, which can lead to remote code execution if uploads are possible. NVD lists Tomcat 7.0.0-7.0.99, 8.5.0-8.5.50 and 9.0.0.M1-9.0.0.30 as affected; Tomcat 5.5 is long unsupported and not in that list, so the template match should be confirmed.
Business impact	Disclosure of application source and configuration (including credentials) and possible remote code execution.
Compliance mapping	CIS Controls v8: CIS 7.1, 7.4, 7.7 NIST CSF 2.0: ID.RA-01; PR.PS-02 ISO/IEC 27001:2022: A.8.8 PCI DSS v4.0 (if in scope): Req. 6.3.1, 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Disable the AJP connector or bind it to localhost; block TCP/8009.
Recommended action: long-term	Upgrade Tomcat to a supported, patched release; if AJP is needed, require a shared secret and restrict by address.
Owner and target	Application owner | SLA 7 days | Target 30 Oct 2026 | Status: Open
Validation note	Template-based detection; Nmap ajp-methods returned no valid OPTIONS response and Tomcat 5.5 is outside the NVD affected-version list, so confirm manually. Rating kept Critical because an exposed, unsupported AJP connector is unsafe either way.

R05 distccd remote command execution

Inherent risk	**Critical | Score 20 (Likelihood 5 Almost certain x Impact 4 Major) | Lab H | P1**
Affected service	TCP/3632; distccd v1 (GNU 4.2.4)
CVE / reference	CVE-2004-2687 CVSS / external severity: 9.3 (CVSS v2, as widely published by NVD; not re-verified)
Detected by	Nmap; Nuclei | Scanner severity: High
Status / validation	Detected by Nuclei template (scanner severity High; assessed higher)
Evidence	Nuclei [CVE-2004-2687] [tcp] [high] 192.168.164.129:3632. Nmap: 3632/tcp distccd v1.
Description	distccd, a distributed compiler daemon, accepts jobs from any client unless restricted. A remote user can run arbitrary commands as the daemon account.
Business impact	Unauthenticated remote command execution as the daemon user and a stepping stone to privilege escalation.
Compliance mapping	CIS Controls v8: CIS 4.1, 4.8 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9 PCI DSS v4.0 (if in scope): Req. 2.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration
Recommended action: immediate	Stop distccd; block TCP/3632.
Recommended action: long-term	Do not expose compile services; if needed, use --allow with specific hosts, bind to an internal interface and add network ACLs.
Owner and target	System administrator | SLA 7 days | Target 30 Oct 2026 | Status: Open
Validation note	Scanner rated High; assessed Critical because the service design permits remote command execution to any permitted client.

R06 VNC remote desktop with weak password and weak protocol

Inherent risk	**Critical | Score 20 (Likelihood 5 Almost certain x Impact 4 Major) | Lab H | P1**
Affected service	TCP/5900; VNC (RFB 003.003)

CVE / reference	Nuclei: vnc-default-login; vnc-service-detect CVSS / external severity: Not scored
Detected by	Nmap; Nuclei | Scanner severity: High
Status / validation	Confirmed by Nuclei credential tests (passwords 'password' and 'password123')
Evidence	Nuclei [vnc-default-login] high x2 (passwords 'password', 'password123'); [vnc-service-detect] RFB 003.003. Nmap vnc-info: protocol 3.3, security type VNC Authentication (2).
Description	Remote desktop access is protected only by weak, guessable passwords over the legacy RFB 3.3 protocol, which uses a weak challenge/response and no session encryption.
Business impact	Interactive desktop control of the host, enabling full compromise, credential capture and tampering.
Compliance mapping	CIS Controls v8: CIS 4.7, 5.2, 6.1 NIST CSF 2.0: PR.AA-01; PR.AA-03 ISO/IEC 27001:2022: A.5.17; A.8.5 PCI DSS v4.0 (if in scope): Req. 2.2.2, 8.3.1, 8.3.6 OWASP Top 10 2021: A07:2021 Identification and Authentication Failures
Recommended action: immediate	Change the VNC password or stop the service; block TCP/5900 except via an SSH tunnel or VPN.
Recommended action: long-term	Replace with an encrypted, MFA-protected remote access method; enforce password policy; monitor remote access.
Owner and target	System administrator | SLA 7 days | Target 30 Oct 2026 | Status: Open
Validation note	Credential success reported by Nuclei.

6.2 High findings (Priority 2, fix within 30 days)

R07 UnrealIRCd 3.2.8.1 (release known to have been trojaned)

Inherent risk	**High | Score 15 (Likelihood 3 Possible x Impact 5 Severe) | Lab H | P2**
Affected service	TCP/6667, 6697; UnrealIRCd 3.2.8.1
CVE / reference	CVE-2010-2075 (applicability to validate) CVSS / external severity: Not scored here
Detected by	Nmap | Scanner severity: n/a (not flagged)
Status / validation	Version indicator only; validate
Evidence	Nmap irc-info on both ports: version 'Unreal3.2.8.1. irc.Metasploitable.LAN'.
Description	Source tarballs of UnrealIRCd 3.2.8.1 distributed in 2009-2010 contained a backdoor allowing remote command execution. A version string alone does not show whether this host runs the trojaned build.
Business impact	If trojaned: unauthenticated remote command execution. Otherwise: an unnecessary, outdated chat service.
Compliance mapping	CIS Controls v8: CIS 7.1, 7.4, 7.7 NIST CSF 2.0: ID.RA-01; PR.PS-02 ISO/IEC 27001:2022: A.8.8 PCI DSS v4.0 (if in scope): Req. 6.3.1, 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Stop the IRC services; block TCP/6667 and 6697.
Recommended action: long-term	Remove IRC from the server; if required, install a supported release from a verified source and compare checksums.
Owner and target	System administrator | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	Do not report as confirmed backdoor without validation (package/source checksum).

R08 Telnet service exposed (cleartext remote login)

Inherent risk	**High | Score 16 (Likelihood 4 Likely x Impact 4 Major) | Lab H | P2**

Affected service	TCP/23; Linux telnetd
CVE / reference	No CVE (insecure protocol) CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap -sV)
Evidence	Nmap: '23/tcp open telnet Linux telnetd'.
Description	Telnet transmits usernames, passwords and session data in plaintext and is obsolete for administration.
Business impact	Credential and session interception on any shared network path, leading to unauthorised access.
Compliance mapping	CIS Controls v8: CIS 3.10, 12.6 NIST CSF 2.0: PR.DS-02 ISO/IEC 27001:2022: A.8.24; A.5.14 PCI DSS v4.0 (if in scope): Req. 2.2.7, 4.2.1 OWASP Top 10 2021: A02:2021 Cryptographic Failures
Recommended action: immediate	Disable telnetd; block TCP/23.
Recommended action: long-term	Use SSH with key-based authentication for administration; apply the baseline that prohibits cleartext management protocols.
Owner and target	System administrator | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	Risk depends on network path and authentication configuration.

R09 Legacy r-services exposed (rexec, rlogin, rsh)

Inherent risk	**High | Score 16 (Likelihood 4 Likely x Impact 4 Major) | Lab H | P2**
Affected service	TCP/512, 513, 514; netkit-rsh rexecd; login; Netkit rshd
CVE / reference	No CVE (insecure protocols) CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap -sV)
Evidence	Nmap: 512/tcp exec netkit-rsh rexecd; 513/tcp login?; 514/tcp shell Netkit rshd.
Description	The r-services use cleartext transport and host-based trust (.rhosts) rather than strong authentication.
Business impact	Unauthorised command execution or login through trusted-host abuse and credential interception.
Compliance mapping	CIS Controls v8: CIS 3.10, 12.6 NIST CSF 2.0: PR.DS-02 ISO/IEC 27001:2022: A.8.24; A.5.14 PCI DSS v4.0 (if in scope): Req. 2.2.7, 4.2.1 OWASP Top 10 2021: A02:2021 Cryptographic Failures
Recommended action: immediate	Disable rexecd, rlogind and rshd; block TCP/512-514.
Recommended action: long-term	Remove the rsh server packages; use SSH only.
Owner and target	System administrator | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	Trust configuration (.rhosts, hosts.equiv) not reviewed.

R10 Anonymous FTP login and weak FTP credentials

Inherent risk	**High | Score 15 (Likelihood 5 Almost certain x Impact 3 Moderate) | Lab H | P2**
Affected service	TCP/21; FTP - vsftpd 2.3.4
CVE / reference	Nmap ftp-anon; Nuclei ftp-anonymous-login; ftp-weak-credentials CVSS / external severity: Not scored

Detected by	Nmap; Nuclei | Scanner severity: High (weak credentials); Medium (anonymous)
Status / validation	Confirmed (Nmap script and Nuclei)
Evidence	Nmap ftp-anon: 'Anonymous FTP login allowed (FTP code 230)'; ftp-syst: control and data connections are plain text. Nuclei [ftp-anonymous-login] medium; [ftp-weak-credentials] high x8 for user 'ftp' (passwords password, default, nas, 123456, guest, stingray, pass1, toor).
Description	The FTP service accepts anonymous login. The eight 'weak credential' hits all use the account 'ftp', which is the anonymous account; they most likely reflect anonymous access accepting any password rather than eight separate weak passwords. FTP also sends data in cleartext.
Business impact	Unauthorised file access or upload, service abuse, and interception of any credentials or data sent over FTP.
Compliance mapping	CIS Controls v8: CIS 4.7, 5.2, 6.1 NIST CSF 2.0: PR.AA-01; PR.AA-03 ISO/IEC 27001:2022: A.5.17; A.8.5 PCI DSS v4.0 (if in scope): Req. 2.2.2, 8.3.1, 8.3.6 OWASP Top 10 2021: A07:2021 Identification and Authentication Failures
Recommended action: immediate	Disable anonymous access unless formally approved; restrict directories and source addresses.
Recommended action: long-term	Replace FTP with SFTP or FTPS; apply least-privilege chroot; review the upload directory.
Owner and target	System administrator | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	Interpretation of the eight weak-credential hits as an anonymous-account artefact is an analyst inference.

R11 Samba 3.0.20 flagged for CVE-2026-4480 (version-based)

Inherent risk	**High | Score 15 (Likelihood 3 Possible x Impact 5 Severe) | Lab H | P2**
Affected service	TCP/445; Samba smbd 3.0.20-Debian
CVE / reference	CVE-2026-4480 CVSS / external severity: 9.0 Critical (CVSS v3.1, AC:H)
Detected by	Nmap; Nuclei | Scanner severity: Critical
Status / validation	Version-based match by Nuclei; applicability to validate
Evidence	Nuclei [CVE-2026-4480:version] [javascript] [critical] 192.168.164.129:445 ['3.0.20']; [samba-detect] 'Samba 3.0.20-Debian'. Nmap: smbd 3.0.20-Debian.
Description	CVE-2026-4480 is an OS command injection in Samba's printing subsystem (the 'print command' %J substitution is not escaped). The Nuclei match is based on the version string. Exploitation depends on the print command configuration and has high attack complexity, so the scanner's Critical label is reduced to High pending validation.
Business impact	Potential remote code execution on the file server.
Compliance mapping	CIS Controls v8: CIS 7.1, 7.4, 7.7 NIST CSF 2.0: ID.RA-01; PR.PS-02 ISO/IEC 27001:2022: A.8.8 PCI DSS v4.0 (if in scope): Req. 6.3.1, 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Restrict TCP/139 and 445 to approved clients; review smb.conf for 'print command' and printing shares.
Recommended action: long-term	Upgrade Samba to a supported, patched release; disable printing support if not needed.
Owner and target	System administrator | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	Public advisories show inconsistent fixed-version data; confirm against the upstream Samba security advisory and the installed build.

R12 SMB weaknesses: SMBv1, guest access and signing disabled

Inherent risk	**High | Score 12 (Likelihood 4 Likely x Impact 3 Moderate) | Lab H | P2**
Affected service	TCP/139, 445 (UDP/137); Samba smbd 3.0.20-Debian
CVE / reference	Nmap smb-security-mode; Nuclei smb-v1-supported CVSS / external severity: Not scored
Detected by	Nmap; Nuclei | Scanner severity: Info
Status / validation	Observed (Nmap and Nuclei)
Evidence	Nmap smb-security-mode: account_used guest; message_signing disabled (dangerous, but default); smb2-time: protocol negotiation failed (SMB2). Nuclei [smb-v1-supported] and [smb-version-detect] 'SMB 1.0'; [ntlm-info] 'Samba 3.0.20-Debian'.
Description	The host speaks only legacy SMB 1.0, allows guest sessions and does not require message signing, which enables relay and tampering attacks.
Business impact	Unauthorised share access, information disclosure and man-in-the-middle manipulation of SMB traffic.
Compliance mapping	CIS Controls v8: CIS 3.3, 6.1, 6.8 NIST CSF 2.0: PR.AA-05 ISO/IEC 27001:2022: A.5.15; A.8.3 PCI DSS v4.0 (if in scope): Req. 7.2 OWASP Top 10 2021: A01:2021 Broken Access Control
Recommended action: immediate	Disable guest access; require SMB signing; restrict to approved hosts.
Recommended action: long-term	Disable SMB1; move to a supported Samba/SMB 3 configuration with encryption.
Owner and target	System administrator | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	Share-level permissions were not enumerated.

R13 PHP-CGI argument injection

Inherent risk	**High | Score 16 (Likelihood 4 Likely x Impact 4 Major) | Lab H | P2**
Affected service	TCP/80; Apache httpd 2.2.8 / PHP 5.2.4
CVE / reference	CVE-2012-1823 CVSS / external severity: 7.5 High (CVSS v3, as widely published by NVD; not re-verified)
Detected by	Nuclei | Scanner severity: High
Status / validation	Detected by Nuclei template (request with -d allow_url_include / auto_prepend_file)
Evidence	Nuclei [CVE-2012-1823] [http] [high] http://192.168.164.129/index.php?-d+allow_url_include%3don+-d+auto_prepend_file%3dphp%3a//input.
Description	PHP running as CGI treats query strings starting with '-' as command-line options, which can expose script source or allow code execution.
Business impact	Source-code disclosure and potential remote code execution through the web server.
Compliance mapping	CIS Controls v8: CIS 7.1, 7.4, 7.7 NIST CSF 2.0: ID.RA-01; PR.PS-02 ISO/IEC 27001:2022: A.8.8 PCI DSS v4.0 (if in scope): Req. 6.3.1, 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Restrict public access to the web server; disable php-cgi in favour of a module/FPM setup.
Recommended action: long-term	Upgrade PHP to a supported version; apply web application firewall rules; include in regular web scans.
Owner and target	Application owner | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	Template-based detection; confirm manually before stating exploitability.

R14 End-of-life web stack: Apache 2.2.8 and PHP 5.2.4

Inherent risk	**High | Score 16 (Likelihood 4 Likely x Impact 4 Major) | Lab H | P2**
Affected service	TCP/80; Apache/2.2.8 (Ubuntu) DAV/2; PHP/5.2.4-2ubuntu5.10
CVE / reference	Nikto outdated-version notice; Nuclei apache-httpd-eol and php-eol CVSS / external severity: Not scored
Detected by	Nmap; Nikto; Nuclei | Scanner severity: Info
Status / validation	Observed (banners)
Evidence	Nikto: 'Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch'; X-Powered-By PHP/5.2.4-2ubuntu5.10. Nuclei [apache-httpd-eol:version] '2.2.8'; [php-eol:version] '5.2.4'.
Description	Both the web server and PHP runtime are well past vendor end of life and no longer receive security updates; many known vulnerabilities (including R13) apply.
Business impact	Web compromise, information disclosure or denial of service; non-compliance with patching expectations.
Compliance mapping	CIS Controls v8: CIS 2.2, 7.4, 7.7 NIST CSF 2.0: PR.PS-02; ID.RA-01 ISO/IEC 27001:2022: A.8.8; A.8.19 PCI DSS v4.0 (if in scope): Req. 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Restrict web exposure to authorised users; plan immediate upgrade path.
Recommended action: long-term	Migrate to supported Apache 2.4.x and PHP 8.x; adopt patch SLAs and automated update monitoring.
Owner and target	Application owner | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	Do not equate banners alone with exploitable CVEs; vendor back-ports may apply.

R15 Legacy database services exposed to the network

Inherent risk	**High | Score 16 (Likelihood 4 Likely x Impact 4 Major) | Lab H | P2**
Affected service	TCP/3306, 5432; MySQL 5.0.51a-3ubuntu5; PostgreSQL 8.3.0 - 8.3.7
CVE / reference	Nmap version banners; Nuclei pgsql-detect CVSS / external severity: Not scored
Detected by	Nmap; Nuclei | Scanner severity: Info
Status / validation	Observed (Nmap -sV)
Evidence	Nmap mysql-info: protocol 10, version 5.0.51a-3ubuntu5, status Autocommit. Nmap: PostgreSQL DB 8.3.0 - 8.3.7. Nuclei [pgsql-detect] info.
Description	Both database engines are unsupported releases directly reachable on the network instead of being limited to application servers.
Business impact	Unauthorised data access, tampering or disruption if authentication or patching is weak (see R03).
Compliance mapping	CIS Controls v8: CIS 2.2, 7.4, 7.7 NIST CSF 2.0: PR.PS-02; ID.RA-01 ISO/IEC 27001:2022: A.8.8; A.8.19 PCI DSS v4.0 (if in scope): Req. 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Bind databases to localhost or an internal interface; restrict by host firewall.
Recommended action: long-term	Upgrade to supported releases; enforce encrypted connections and least-privilege accounts.
Owner and target	Database administrator | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	MySQL authentication was not tested in this assessment.

R16 Ruby DRb (distributed Ruby) service exposed

Inherent risk	**High | Score 16 (Likelihood 4 Likely x Impact 4 Major) | Lab H | P2**
Affected service	TCP/8787; Ruby DRb RMI (Ruby 1.8)
CVE / reference	Nmap service identification CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap -sV); exploitability to validate
Evidence	Nmap: '8787/tcp open drb Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)'.
Description	DRb exposes Ruby objects over the network and, unless access control and taint checks are configured, can allow remote method invocation that leads to code execution.
Business impact	Potential remote code execution on the host.
Compliance mapping	CIS Controls v8: CIS 4.1, 4.8 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9 PCI DSS v4.0 (if in scope): Req. 2.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration
Recommended action: immediate	Stop the DRb service; block TCP/8787.
Recommended action: long-term	Remove unnecessary Ruby services; if needed, bind to localhost and use ACLs.
Owner and target	System administrator | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	Access-control configuration not reviewed.

R17 End-of-life Apache Tomcat 5.5 application server

Inherent risk	**High | Score 16 (Likelihood 4 Likely x Impact 4 Major) | Lab H | P2**
Affected service	TCP/8180; Apache Tomcat/Coyote JSP engine 1.1 (Tomcat 5.5)
CVE / reference	Nmap http-title 'Apache Tomcat/5.5' CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap)
Evidence	Nmap: 8180/tcp http Apache Tomcat/Coyote JSP engine 1.1; http-title Apache Tomcat/5.5; http-server-header Apache-Coyote/1.1.
Description	Tomcat 5.5 has been unsupported for many years, accumulates unpatched vulnerabilities and often retains a default manager interface.
Business impact	Application compromise, credential exposure and possible code deployment through management interfaces.
Compliance mapping	CIS Controls v8: CIS 2.2, 7.4, 7.7 NIST CSF 2.0: PR.PS-02; ID.RA-01 ISO/IEC 27001:2022: A.8.8; A.8.19 PCI DSS v4.0 (if in scope): Req. 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Restrict access to TCP/8180; verify that default manager credentials and sample apps are removed.
Recommended action: long-term	Upgrade to a supported Tomcat release; remove sample applications; apply a hardening baseline.
Owner and target	Application owner | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	Manager interface and credentials not tested.

R18 SSLv2 and weak ciphers supported by SMTP service

Inherent risk	**High | Score 12 (Likelihood 3 Possible x Impact 4 Major) | Lab H | P2**
Affected service	TCP/25; Postfix smtpd
CVE / reference	Nmap sslv2 script; obsolete protocol (no CVE) CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap script)
Evidence	Nmap sslv2: 'SSLv2 supported' with ciphers SSL2_RC4_128_WITH_MD5, SSL2_DES_192_EDE3_CBC_WITH_MD5, SSL2_RC4_128_EXPORT40_WITH_MD5, SSL2_RC2_128_CBC_EXPORT40_WITH_MD5, SSL2_RC2_128_CBC_WITH_MD5, SSL2_DES_64_CBC_WITH_MD5.
Description	SSLv2 is a broken protocol, and the offered ciphers include export-grade, single DES and MD5-based suites.
Business impact	Weakened confidentiality and integrity of mail transport and possible downgrade attacks.
Compliance mapping	CIS Controls v8: CIS 3.10, 12.6 NIST CSF 2.0: PR.DS-02 ISO/IEC 27001:2022: A.8.24; A.5.14 PCI DSS v4.0 (if in scope): Req. 2.2.7, 4.2.1 OWASP Top 10 2021: A02:2021 Cryptographic Failures
Recommended action: immediate	Disable SSLv2 and SSLv3 in the Postfix TLS settings.
Recommended action: long-term	Allow only TLS 1.2+ with modern cipher suites; renew certificates (see R31).
Owner and target	Messaging administrator | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	Observed by Nmap script.

R19 Unsupported legacy operating system

Inherent risk	**High | Score 16 (Likelihood 4 Likely x Impact 4 Major) | Lab H | P2**
Affected service	Host; Linux 2.6.9 - 2.6.33
CVE / reference	Nmap OS detection CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap -O, 100% match)
Evidence	Nmap: 'OS match: Linux 2.6.9 - 2.6.33 (100%)'; OS CPE cpe:/o:linux:linux_kernel:2.6; package banners such as 'Ubuntu 4.2.4-1ubuntu4' indicate an old Ubuntu release.
Description	The kernel and distribution are far beyond vendor support, so security fixes for the OS and base packages are unavailable.
Business impact	Persistent exposure to known kernel and library vulnerabilities, including local privilege escalation.
Compliance mapping	CIS Controls v8: CIS 2.2, 7.4, 7.7 NIST CSF 2.0: PR.PS-02; ID.RA-01 ISO/IEC 27001:2022: A.8.8; A.8.19 PCI DSS v4.0 (if in scope): Req. 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Keep the host isolated; do not store real data.
Recommended action: long-term	Rebuild on a supported OS from a hardened baseline image.
Owner and target	System administrator | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	OS fingerprint is probabilistic.

R20 Excessive attack surface and no network filtering

Inherent risk	**High | Score 15 (Likelihood 5 Almost certain x Impact 3 Moderate) | Lab H | P2**
Affected service	30 open TCP ports; Host-wide
CVE / reference	Nmap full TCP scan CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap -p-)
Evidence	Nmap: 65,535 ports scanned; 30 open; 65,505 closed (reset); 0 filtered.
Description	Thirty services listen with no sign of host or network firewall filtering (every closed port answers with a reset). Most of the services are unnecessary for a development server.
Business impact	Large attack surface that multiplies the likelihood that at least one weakness is exploited.
Compliance mapping	CIS Controls v8: CIS 4.4, 12.2, 13.4 NIST CSF 2.0: PR.IR-01 ISO/IEC 27001:2022: A.8.20; A.8.22 PCI DSS v4.0 (if in scope): Req. 1.3, 1.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration
Recommended action: immediate	Apply a default-deny host firewall and allow only required ports from named sources.
Recommended action: long-term	Adopt a secure build baseline (CIS Benchmark) that disables unused services; record the asset in the inventory with an owner and purpose.
Owner and target	Network/security engineer | SLA 30 days | Target 22 Nov 2026 | Status: Open
Validation note	Observed from a single same-segment scanner.

6.3 Medium findings (Priority 3, fix within 90 days)

R21 NFS and RPC portmapper services exposed

Inherent risk	**Medium | Score 9 (Likelihood 3 Possible x Impact 3 Moderate) | Lab M | P3**
Affected service	TCP/111, 2049, 54313, 54570, 54727 (UDP/111); rpcbind; nfs 2-4; mountd; nlockmgr; status
CVE / reference	Nmap rpcinfo; Nuclei nfs-v3-exposed, rpc-udp-detect CVSS / external severity: Not scored
Detected by	Nmap; Nuclei | Scanner severity: Info
Status / validation	Observed; export list not enumerated
Evidence	Nmap rpcinfo lists nfs (100003) versions 2,3,4 on 2049, mountd (100005), nlockmgr (100021) and status (100024). Nuclei [nfs-v3-exposed] info on 2049; [rpc-udp-detect] on UDP/111.
Description	NFS and RPC services allow remote mounting of exported file systems; exports with weak host restrictions can expose files.
Business impact	Possible unauthorised file read/write if exports are open.
Compliance mapping	CIS Controls v8: CIS 3.3, 6.1, 6.8 NIST CSF 2.0: PR.AA-05 ISO/IEC 27001:2022: A.5.15; A.8.3 PCI DSS v4.0 (if in scope): Req. 7.2 OWASP Top 10 2021: A01:2021 Broken Access Control
Recommended action: immediate	Block RPC/NFS from untrusted hosts; review /etc/exports.
Recommended action: long-term	Disable NFS where unneeded; otherwise use NFSv4 with Kerberos and strict export lists.
Owner and target	System administrator | SLA 90 days | Target 21 Jan 2027 | Status: Open
Validation note	Run showmount -e in the lab to confirm exports before rating higher.

R22 phpMyAdmin administration interface exposed

Inherent risk	**Medium | Score 9 (Likelihood 3 Possible x Impact 3 Moderate) | Lab M | P3**
Affected service	TCP/80; phpMyAdmin (under /phpMyAdmin/)
CVE / reference	Nikto; Nuclei phpmyadmin-panel CVSS / external severity: Not scored
Detected by	Nikto; Nuclei | Scanner severity: Info
Status / validation	Observed (Nikto and Nuclei)
Evidence	Nuclei [phpmyadmin-panel] info /phpMyAdmin/. Nikto: /phpMyAdmin/, /phpMyAdmin/changelog.php, /phpMyAdmin/ChangeLog, /phpMyAdmin/Documentation.html and /phpMyAdmin/README found; 'should be protected or limited to authorized hosts'.
Description	A database administration console is reachable from the web without network restriction, which gives attackers a convenient brute-force and exploitation target.
Business impact	Database takeover if weak credentials or vulnerabilities exist.
Compliance mapping	CIS Controls v8: CIS 3.3, 6.1, 6.8 NIST CSF 2.0: PR.AA-05 ISO/IEC 27001:2022: A.5.15; A.8.3 PCI DSS v4.0 (if in scope): Req. 7.2 OWASP Top 10 2021: A01:2021 Broken Access Control
Recommended action: immediate	Restrict /phpMyAdmin/ to administrator IPs or remove it.
Recommended action: long-term	Upgrade or remove; require MFA or VPN for administrative tools; remove changelog and documentation files.
Owner and target	Application owner | SLA 90 days | Target 21 Jan 2027 | Status: Open
Validation note	Login strength not tested.

R23 phpinfo() test script exposed

Inherent risk	**Medium | Score 8 (Likelihood 4 Likely x Impact 2 Minor) | Lab M | P3**
Affected service	TCP/80; /phpinfo.php
CVE / reference	CWE-552; Nuclei phpinfo-files CVSS / external severity: Not scored
Detected by	Nikto; Nuclei | Scanner severity: Low
Status / validation	Observed (Nikto and Nuclei)
Evidence	Nikto: '/phpinfo.php: Output from the phpinfo() function was found' (CWE-552). Nuclei [phpinfo-files] low.
Description	phpinfo() reveals PHP configuration, loaded modules, paths and environment variables.
Business impact	Reconnaissance data that makes targeted attacks easier.
Compliance mapping	CIS Controls v8: CIS 16.7, 4.1 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9 PCI DSS v4.0 (if in scope): Req. 6.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration (CWE-200)
Recommended action: immediate	Delete phpinfo.php.
Recommended action: long-term	Add a release check that removes diagnostic scripts from deployed environments.
Owner and target	Application owner | SLA 90 days | Target 21 Jan 2027 | Status: Open
Validation note	Observed.

R24 Directory indexing and browsable documentation paths

Inherent risk	**Medium | Score 8 (Likelihood 4 Likely x Impact 2 Minor) | Lab M | P3**
Affected service	TCP/80; /doc/, /test/, /icons/
CVE / reference	CVE-1999-0678 (/doc/); Nikto CVSS / external severity: Not scored
Detected by	Nikto | Scanner severity: n/a
Status / validation	Observed (Nikto)
Evidence	Nikto: '/doc/: Directory indexing found'; '/doc/: The /doc/ directory is browsable. This may be /usr/doc. See CVE-1999-0678'; '/test/: Directory indexing found'; '/icons/: Directory indexing found'; '/icons/README: Apache default file found'.
Description	Directory listings expose file names, test content and installed documentation.
Business impact	Information disclosure and discovery of further attack targets.
Compliance mapping	CIS Controls v8: CIS 16.7 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9; A.8.26 PCI DSS v4.0 (if in scope): Req. 6.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration
Recommended action: immediate	Disable Options Indexes; remove /test/ and default content.
Recommended action: long-term	Use a hardened Apache configuration template (CIS Apache Benchmark).
Owner and target	Application owner | SLA 90 days | Target 21 Jan 2027 | Status: Open
Validation note	Observed.

R25 Possible credential file '#wp-config.php#' reported

Inherent risk	**Medium | Score 8 (Likelihood 2 Unlikely x Impact 4 Major) | Lab M | P3**
Affected service	TCP/80; /#wp-config.php#
CVE / reference	Nikto finding CVSS / external severity: Not scored
Detected by	Nikto | Scanner severity: n/a
Status / validation	Unverified scanner finding - confirm manually
Evidence	Nikto: '/#wp-config.php#: #wp-config.php# file found. This file contains the credentials.'
Description	Nikto reports an editor backup of a WordPress configuration file that, if real, would contain database credentials. The text is a generic Nikto message and the file may not exist.
Business impact	If confirmed: disclosure of database credentials and takeover of the application's data.
Compliance mapping	CIS Controls v8: CIS 16.7, 4.1 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9 PCI DSS v4.0 (if in scope): Req. 6.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration (CWE-200)
Recommended action: immediate	Request the URL manually; if present, remove and rotate the credentials it contains.
Recommended action: long-term	Block access to backup and temporary files; scan builds for secrets.
Owner and target	Application owner | SLA 90 days | Target 21 Jan 2027 | Status: Open
Validation note	Likely lower confidence; raise to High only after confirmation.

R26 Legacy OpenSSH 4.7p1 with 1024-bit DSA host key

Inherent risk	**Medium | Score 9 (Likelihood 3 Possible x Impact 3 Moderate) | Lab M | P3**
Affected service	TCP/22; OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
CVE / reference	Nmap ssh-hostkey; Nuclei openssh-detect CVSS / external severity: Not scored
Detected by	Nmap; Nuclei | Scanner severity: Info
Status / validation	Observed (Nmap)
Evidence	Nmap ssh-hostkey: 1024-bit DSA (60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd) and 2048-bit RSA (56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3). Nuclei [openssh-detect] 'SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1'.
Description	The SSH server is a very old release and offers a 1024-bit DSA host key, which no longer meets minimum key-strength guidance.
Business impact	Weak cryptographic assurance and exposure to known OpenSSH flaws.
Compliance mapping	CIS Controls v8: CIS 2.2, 7.4, 7.7 NIST CSF 2.0: PR.PS-02; ID.RA-01 ISO/IEC 27001:2022: A.8.8; A.8.19 PCI DSS v4.0 (if in scope): Req. 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Restrict SSH to management hosts.
Recommended action: long-term	Upgrade OpenSSH; regenerate host keys (Ed25519 or RSA 3072+); disable password logins where possible.
Owner and target	System administrator | SLA 90 days | Target 21 Jan 2027 | Status: Open
Validation note	Confirm package patch level.

R27 Legacy ISC BIND 9.4.2 DNS service

Inherent risk	**Medium | Score 9 (Likelihood 3 Possible x Impact 3 Moderate) | Lab M | P3**
Affected service	TCP/53; ISC BIND 9.4.2
CVE / reference	Nmap dns-nsid CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap)
Evidence	Nmap: '53/tcp open domain ISC BIND 9.4.2'; dns-nsid bind.version: 9.4.2.
Description	BIND 9.4.2 is obsolete and discloses its version. A development server rarely needs to run an authoritative or recursive DNS service.
Business impact	Exposure to DNS software flaws and possible abuse as a resolver.
Compliance mapping	CIS Controls v8: CIS 2.2, 7.4, 7.7 NIST CSF 2.0: PR.PS-02; ID.RA-01 ISO/IEC 27001:2022: A.8.8; A.8.19 PCI DSS v4.0 (if in scope): Req. 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Disable named if not required, or limit queries to approved clients.
Recommended action: long-term	Upgrade to a supported BIND release; hide version; restrict recursion and zone transfers.
Owner and target	Network/security engineer | SLA 90 days | Target 21 Jan 2027 | Status: Open
Validation note	Recursion and zone-transfer settings not tested.

R28 Legacy ProFTPD 1.3.1 on alternate FTP port

Inherent risk	**Medium | Score 9 (Likelihood 3 Possible x Impact 3 Moderate) | Lab M | P3**
Affected service	TCP/2121; ProFTPD 1.3.1
CVE / reference	Nmap -sV CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap)
Evidence	Nmap: '2121/tcp open ftp ProFTPD 1.3.1'.
Description	A second, outdated FTP server runs on a non-standard port, doubling the FTP exposure and escaping simple port-based controls.
Business impact	Cleartext file transfer and exposure to ProFTPD vulnerabilities.
Compliance mapping	CIS Controls v8: CIS 2.2, 7.4, 7.7 NIST CSF 2.0: PR.PS-02; ID.RA-01 ISO/IEC 27001:2022: A.8.8; A.8.19 PCI DSS v4.0 (if in scope): Req. 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Stop the service or restrict by host firewall.
Recommended action: long-term	Remove or replace with SFTP.
Owner and target	System administrator | SLA 90 days | Target 21 Jan 2027 | Status: Open
Validation note	Authentication not tested.

R29 Java RMI registry services exposed

Inherent risk	**Medium | Score 9 (Likelihood 3 Possible x Impact 3 Moderate) | Lab M | P3**
Affected service	TCP/1099, 59365; GNU Classpath grmiregistry
CVE / reference	Nmap -sV CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap)
Evidence	Nmap: 1099/tcp and 59365/tcp java-rmi GNU Classpath grmiregistry.
Description	Exposed RMI registries can allow enumeration and, depending on class loading settings, remote code execution.
Business impact	Potential remote code execution or information disclosure.
Compliance mapping	CIS Controls v8: CIS 4.1, 4.8 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9 PCI DSS v4.0 (if in scope): Req. 2.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration
Recommended action: immediate	Block TCP/1099 and 59365 from untrusted hosts.
Recommended action: long-term	Disable unneeded RMI services; configure serialization filters and authentication.
Owner and target	Application owner | SLA 90 days | Target 21 Jan 2027 | Status: Open
Validation note	Class-loading configuration not reviewed.

R30 Additional vsftpd CVEs flagged by version match

Inherent risk	**Medium | Score 9 (Likelihood 3 Possible x Impact 3 Moderate) | Lab M | P3**
Affected service	TCP/21; vsftpd 2.3.4
CVE / reference	CVE-2015-1419; CVE-2021-30047 CVSS / external severity: CVE-2015-1419: 5.0 Medium; CVE-2021-30047: 7.5 High (as listed)
Detected by	Nuclei | Scanner severity: Medium; High
Status / validation	Version-based; low confidence - validate
Evidence	Nuclei [CVE-2015-1419:version] [tcp] [medium] and [CVE-2021-30047:version] [tcp] [high] on 192.168.164.129:21 ['2.3.4'].
Description	CVE-2015-1419 (deny_file parsing, vsftpd 3.0.2 and earlier) plausibly applies to 2.3.4. NVD lists CVE-2021-30047 (connection-limit denial of service) only for vsftpd 3.0.3, so that match is probably a false positive.
Business impact	Access-restriction bypass or denial of service of the FTP service.
Compliance mapping	CIS Controls v8: CIS 7.1, 7.4, 7.7 NIST CSF 2.0: ID.RA-01; PR.PS-02 ISO/IEC 27001:2022: A.8.8 PCI DSS v4.0 (if in scope): Req. 6.3.1, 6.3.3 OWASP Top 10 2021: A06:2021 Vulnerable and Outdated Components
Recommended action: immediate	Covered by removing vsftpd (see R01).
Recommended action: long-term	Upgrade to a supported release.
Owner and target	System administrator | SLA 90 days | Target 21 Jan 2027 | Status: Open
Validation note	CVE-2021-30047 probable false positive; keep as a documented scanner discrepancy.

6.4 Low findings (Priority 4, fix within 180 days)

R31 Expired TLS certificates on SMTP and PostgreSQL

Inherent risk	**Low | Score 6 (Likelihood 3 Possible x Impact 2 Minor) | Lab L | P4**
Affected service	TCP/25, 5432; Certificate CN=ubuntu804-base.localdomain
CVE / reference	Nmap ssl-cert; ssl-date CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap)
Evidence	Nmap ssl-cert: Subject commonName=ubuntu804-base.localdomain, organizationName=OCOSA; Not valid before 2010-03-17T14:07:45; Not valid after 2010-04-16T14:07:45. Scan date 2026-10-22.
Description	The certificates expired in April 2010, more than sixteen years before the scan, so clients cannot rely on them for identity or trust.
Business impact	Trust failure, certificate warnings that train users to ignore errors, and weakened transport security.
Compliance mapping	CIS Controls v8: CIS 3.10, 12.6 NIST CSF 2.0: PR.DS-02 ISO/IEC 27001:2022: A.8.24; A.5.14 PCI DSS v4.0 (if in scope): Req. 2.2.7, 4.2.1 OWASP Top 10 2021: A02:2021 Cryptographic Failures
Recommended action: immediate	Note for remediation; no immediate action beyond isolation.
Recommended action: long-term	Issue certificates from an approved CA with managed renewal and inventory.
Owner and target	Messaging / database administrator | SLA 180 days | Target 21 Apr 2027 | Status: Open

Validation note	Observed.

R32 SMTP user enumeration commands enabled (VRFY, ETRN)

Inherent risk	**Low | Score 6 (Likelihood 3 Possible x Impact 2 Minor) | Lab L | P4**
Affected service	TCP/25; Postfix smtpd
CVE / reference	Nmap smtp-commands; Nuclei smtp-commands-enum CVSS / external severity: Not scored
Detected by	Nmap; Nuclei | Scanner severity: Info
Status / validation	Observed (Nmap and Nuclei)
Evidence	Nuclei [smtp-commands-enum:ehlo] ['DSN','PIPELINING','SIZE 10240000','VRFY','ETRN','STARTTLS','ENHANCEDSTATUSCODES','8BITMIME']. Nmap smtp-commands lists the same.
Description	VRFY allows an attacker to test whether local accounts exist; ETRN can trigger queue processing.
Business impact	Account discovery that supports password-guessing and phishing.
Compliance mapping	CIS Controls v8: CIS 16.7, 4.1 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9 PCI DSS v4.0 (if in scope): Req. 6.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration (CWE-200)
Recommended action: immediate	Set disable_vrfy_command = yes and restrict ETRN.
Recommended action: long-term	Harden mail configuration to a baseline.
Owner and target	Messaging administrator | SLA 180 days | Target 21 Apr 2027 | Status: Open
Validation note	Observed.

R33 HTTP TRACE method enabled

Inherent risk	**Low | Score 6 (Likelihood 3 Possible x Impact 2 Minor) | Lab L | P4**
Affected service	TCP/80; Apache httpd 2.2.8
CVE / reference	Cross-Site Tracing (OWASP); Nuclei http-trace CVSS / external severity: Not scored
Detected by	Nikto; Nuclei | Scanner severity: Info
Status / validation	Observed (Nikto and Nuclei)
Evidence	Nikto: 'HTTP TRACE method is active which suggests the host is vulnerable to XST.' Nuclei [http-trace:trace-request] info.
Description	TRACE echoes requests back, which historically helped attackers steal cookie data through cross-site tracing.
Business impact	Low on its own; adds to client-side attack options.
Compliance mapping	CIS Controls v8: CIS 16.7 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9; A.8.26 PCI DSS v4.0 (if in scope): Req. 6.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration
Recommended action: immediate	Add TraceEnable off.
Recommended action: long-term	Include in the web server baseline.
Owner and target	Application owner | SLA 180 days | Target 21 Apr 2027 | Status: Open

Validation note	Modern browsers block XST; severity kept Low.

R34 Missing HTTP security response headers

Inherent risk	**Low | Score 6 (Likelihood 3 Possible x Impact 2 Minor) | Lab L | P4**
Affected service	TCP/80; Apache httpd 2.2.8
CVE / reference	OWASP Secure Headers; Nuclei http-missing-security-headers CVSS / external severity: Not scored
Detected by	Nikto; Nuclei | Scanner severity: Info (x10)
Status / validation	Observed (Nikto and Nuclei)
Evidence	Nikto: X-Frame-Options and X-Content-Type-Options not set. Nuclei lists ten missing headers: content-security-policy, x-content-type-options, x-permitted-cross-domain-policies, cross-origin-opener-policy, permissions-policy, x-frame-options, referrer-policy, cross-origin-embedder-policy, cross-origin-resource-policy, strict-transport-security.
Description	Without these headers browsers apply fewer protections against clickjacking, MIME sniffing and cross-origin leaks. HSTS is moot while the site is HTTP only.
Business impact	Increased exposure of users to client-side attacks.
Compliance mapping	CIS Controls v8: CIS 16.7 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9; A.8.26 PCI DSS v4.0 (if in scope): Req. 6.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration
Recommended action: immediate	Add headers in Apache configuration for the pages that remain in use.
Recommended action: long-term	Serve over HTTPS with HSTS and a reviewed CSP.
Owner and target	Application owner | SLA 180 days | Target 21 Apr 2027 | Status: Open
Validation note	Observed.

R35 Information leakage through headers, ETag and error behaviour

Inherent risk	**Low | Score 6 (Likelihood 3 Possible x Impact 2 Minor) | Lab L | P4**
Affected service	TCP/80; Apache httpd 2.2.8 / PHP 5.2.4
CVE / reference	CVE-2003-1418; OSVDB-12184; Nuclei apache-mod-negotiation-listing CVSS / external severity: Not scored
Detected by	Nikto; Nuclei | Scanner severity: Low
Status / validation	Observed (Nikto and Nuclei)
Evidence	Nikto: X-Powered-By PHP/5.2.4-2ubuntu5.10; ETag inode leak on /phpMyAdmin/ChangeLog (inode 92462, size 40540, CVE-2003-1418); 'tcn' header and MultiViews on /index; PHP query-string information disclosure (OSVDB-12184) x4; junk HTTP method KOVKERUA accepted. Nuclei [apache-mod-negotiation-listing] low; [php-detect] 5.2.4; [waf-detect:apachegeneric]; [tech-detect:php].
Description	Verbose headers and default behaviours reveal exact software versions and file system details that help an attacker choose exploits.
Business impact	Reconnaissance value only; supports other attacks.
Compliance mapping	CIS Controls v8: CIS 16.7, 4.1 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9 PCI DSS v4.0 (if in scope): Req. 6.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration (CWE-200)
Recommended action: immediate	Set ServerTokens Prod, ExposePHP off, FileETag MTime Size; disable MultiViews.

Recommended action: long-term	Harden to a baseline and re-scan.
Owner and target	Application owner | SLA 180 days | Target 21 Apr 2027 | Status: Open
Validation note	The junk-method response may be a false positive per Nikto.

R36 Large clock skew relative to scanner

Inherent risk	**Low | Score 4 (Likelihood 2 Unlikely x Impact 2 Minor) | Lab L | P4**
Affected service	Host; System time
CVE / reference	Nmap clock-skew CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed (Nmap)
Evidence	Nmap clock-skew: mean 1h00m05s, deviation 2h00m00s, median 4s.
Description	The target clock differs from the scanner by about one hour on average, which can reflect a time-zone setting rather than drift. Consistent time is needed for log correlation and Kerberos.
Business impact	Unreliable log timelines for investigations.
Compliance mapping	CIS Controls v8: CIS 8.4 NIST CSF 2.0: PR.PS-04 ISO/IEC 27001:2022: A.8.17 PCI DSS v4.0 (if in scope): Req. 10.6 OWASP Top 10 2021: n/a
Recommended action: immediate	None beyond note.
Recommended action: long-term	Configure NTP and a standard time zone.
Owner and target	System administrator | SLA 180 days | Target 21 Apr 2027 | Status: Open
Validation note	Likely a VM time-zone or configuration effect.

R37 X11 service listening

Inherent risk	**Low | Score 6 (Likelihood 2 Unlikely x Impact 3 Moderate) | Lab L | P4**
Affected service	TCP/6000; X11
CVE / reference	Nmap -sV CVSS / external severity: Not scored
Detected by	Nmap | Scanner severity: n/a
Status / validation	Observed; access denied at time of scan
Evidence	Nmap: '6000/tcp open X11 (access denied)'.
Description	An X11 server accepts network connections. Access was denied, which limits current risk, but the listener should not be reachable.
Business impact	Potential screen/keystroke exposure if access control is relaxed.
Compliance mapping	CIS Controls v8: CIS 4.1, 4.8 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9 PCI DSS v4.0 (if in scope): Req. 2.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration
Recommended action: immediate	Disable remote X11 (-nolisten tcp).

Recommended action: long-term	Use SSH X11 forwarding only where needed.
Owner and target	System administrator | SLA 180 days | Target 21 Apr 2027 | Status: Open
Validation note	Access control is working at the time of scan.

R38 NetBIOS and RPC information disclosure

Inherent risk	**Low | Score 6 (Likelihood 3 Possible x Impact 2 Minor) | Lab L | P4**
Affected service	UDP/137, UDP/111; NetBIOS name service; RPC portmapper
CVE / reference	Nuclei netbios-udp-detect, rpc-udp-detect; Nmap nbstat, smb-os-discovery CVSS / external severity: Not scored
Detected by	Nmap; Nuclei | Scanner severity: Info
Status / validation	Observed (Nmap and Nuclei)
Evidence	Nuclei [netbios-udp-detect] on UDP/137; [rpc-udp-detect] on UDP/111. Nmap nbstat: NetBIOS name METASPLOITABLE; smb-os-discovery: OS Unix (Samba 3.0.20-Debian), computer name metasploitable, domain localdomain, FQDN metasploitable.localdomain.
Description	Name services disclose host name, domain and OS details that assist reconnaissance.
Business impact	Reconnaissance support.
Compliance mapping	CIS Controls v8: CIS 16.7, 4.1 NIST CSF 2.0: PR.PS-01 ISO/IEC 27001:2022: A.8.9 PCI DSS v4.0 (if in scope): Req. 6.2.4 OWASP Top 10 2021: A05:2021 Security Misconfiguration (CWE-200)
Recommended action: immediate	Block UDP/137 and 111 from untrusted hosts.
Recommended action: long-term	Disable NetBIOS over TCP/IP where not needed.
Owner and target	Network/security engineer | SLA 180 days | Target 21 Apr 2027 | Status: Open
Validation note	Observed.

7. Compliance and GRC Interpretation

Exposed or unnecessary services can conflict with secure configuration, asset management, vulnerability management, access control and data protection objectives. The mappings in this report are indicative control alignments rather than a formal finding of non-compliance. A formal conclusion requires confirmation of the applicable framework, system scope, control requirements, business context and evidence of control operation.

7.1 Answer to the question- why is knowing which ports are open a compliance issue?

Open ports such as 21/FTP and 23/Telnet are a compliance matter, not just a technical one, for five reasons:

- **Attack surface reduction.** Frameworks expect only necessary services, ports and protocols to be enabled and justified (CIS 4.8 and 12.2; NIST CSF 2.0 PR.PS-01, which replaces PR.IP-1 in CSF 1.1; ISO 27001 A.8.9; PCI DSS 2.2.4). This host had 30 open ports and none were filtered.
- **Cleartext protocols breach data-protection requirements.** FTP, Telnet and the r-services send credentials unencrypted (CIS 3.10 and 12.6; NIST CSF PR.DS-02; ISO A.8.24; PCI DSS 2.2.7 and 4.2.1).
- **Asset and owner accountability.** Every listening service should have a documented owner and purpose in the asset inventory (CIS 1.1; NIST CSF ID.AM-01; ISO A.5.9). None is recorded for this host.
- **Vulnerability management.** Version banners on open ports are the input for patch and vulnerability processes (CIS 7.1, 7.4, 7.7; ISO A.8.8). Many services here are past end of life.
- **Audit evidence.** A port inventory with scan dates, owners and approved exceptions is the evidence an auditor will ask for; without it, control operation cannot be demonstrated. The lab brief cites CIS Control 9 (v7), which corresponds to v8 safeguards 4.8, 12.2 and 13.4.

7.2 Control themes and management implications

Table 16: *Control themes, related findings and implications*

Control theme	Related findings	Principal frameworks	Implication for management
Vulnerability and patch management	R01, R04, R05, R07, R11, R13-R15, R17, R19, R26-R30	CIS 2.2, 7.1-7.7; CSF ID.RA-01, PR.PS-02; ISO A.8.8; PCI 6.3	No supported-software or patch process is evident for this asset; define patch SLAs and end-of-life tracking.
Secure configuration and hardening	R02, R09, R16, R20, R24, R29, R33-R35, R37	CIS 4.1, 4.8, 16.7; CSF PR.PS-01; ISO A.8.9; PCI 2.2	Deployments do not use a security baseline; adopt CIS Benchmarks and a gold image.
Identity, authentication and access	R03, R06, R10, R12, R21, R22	CIS 4.7, 5.2, 6.1, 3.3; CSF PR.AA; ISO A.5.15, A.5.17, A.8.5; PCI 7, 8	Default and empty credentials remain; enforce password policy and remove default accounts.
Cryptography and data in transit	R08, R09, R10, R18, R31	CIS 3.10, 12.6; CSF PR.DS-02; ISO A.8.24; PCI 2.2.7, 4.2.1	Management and file transfer use cleartext protocols; mandate encrypted protocols.
Network security and segmentation	R20	CIS 4.4, 12.2, 13.4; CSF PR.IR-01; ISO A.8.20, A.8.22; PCI 1	No host or network filtering; development systems must be segregated from production (ISO A.8.31).
Information disclosure	R23, R25, R32, R35, R38	CIS 16.7; CSF PR.PS-01; OWASP A05	Diagnostic scripts, banners and test content were left in place; add release checks.
Logging and time	R36	CIS 8.4; CSF PR.PS-04; ISO A.8.17; PCI 10.6	Time differences weaken incident timelines; standardise NTP and time zone.

7.3 Framework numbering used and the lab brief

This report uses CIS Controls v8, NIST Cybersecurity Framework 2.0, ISO/IEC 27001:2022 Annex A, PCI DSS v4.0 and OWASP Top 10 2021. The lab brief quotes older numbering. The table below shows how each cited reference maps to the current one.

Table 17: *Lab-brief references and current equivalents*

Lab-brief reference	Meaning	Current equivalent used here
NIST CSF ID.AM-1 / CIS Control 1	Asset inventory	CSF 2.0 ID.AM-01; CIS v8 1.1
NIST CSF PR.IP-1 / CIS Control 9	Baseline configuration; limitation of ports, protocols and services	CSF 2.0 PR.PS-01; CIS v8 4.1, 4.8, 12.2, 13.4
NIST CSF PR.AC-1 / CIS 5.2	Credential and identity management; unique passwords	CSF 2.0 PR.AA-01; CIS v8 5.2, 4.7
NIST CSF PR.DS-2	Data in transit protected	CSF 2.0 PR.DS-02; CIS v8 3.10
CIS 7.1 (patch management)	Vulnerability management process	CIS v8 7.1, 7.4, 7.7
PCI DSS Requirement 6	Secure systems and software	PCI DSS v4.0 Req. 6.2, 6.3 (if in scope)
OWASP Top 10	Web application risk categories	OWASP Top 10 2021 (A01, A02, A05, A06, A07)

7.4 Scope caution for PCI DSS

> PCI DSS requirements are quoted only as indicative alignments. They apply only if this server stores, processes or transmits cardholder data or can affect the security of the cardholder-data environment. A development server holding no cardholder data would normally be out of scope.

8. Remediation Roadmap

Table 18: *Phased remediation plan*

Phase	Timeline and target	Findings	Key actions	Exit criteria
Phase 0 Contain	Immediately (0-24 hours)	All (host level)	Isolate on a host-only or VLAN network with no route to production; snapshot for evidence; record owner and purpose.	Failed scan or ping from the production network.
Phase 1 Remove critical exposure (P1)	0-7 days by 30 Oct 2026	R01, R02, R03, R04, R05, R06	Disable vsftpd, the bind shell, distccd and AJP; reset PostgreSQL and VNC credentials and restrict listeners; block ports in a default-deny host firewall.	Re-scan shows ports closed or restricted; Nuclei critical results cleared.
Phase 2 Reduce high risk (P2)	8-30 days by 22 Nov 2026	R07, R08, R09, R10, R11, R12, R13, R14, R15, R16, R17, R18, R19, R20	Disable Telnet, r-services, anonymous FTP and IRC; patch or retire Samba, PHP, Apache, Tomcat, databases and DRb; disable SMBv1 and require signing; remove SSLv2; apply a firewall allow-list; plan OS rebuild.	No High findings remain, or risk acceptance with compensating controls is signed.
Phase 3 Harden and tidy (P3)	31-90 days by 21 Jan 2027	R21, R22, R23, R24, R25, R26, R27, R28, R29, R30	Restrict NFS, phpMyAdmin and RMI; remove phpinfo and test content; disable directory indexing; upgrade SSH and BIND; verify the #wp-config.php# result.	Web scan clean of exposed test content; Medium findings closed or scheduled.
Phase 4 Routine improvement (P4)	91-180 days by 21 Apr 2027	R31, R32, R33, R34, R35, R36, R37, R38	Add security headers, hide version banners, disable TRACE and VRFY, renew certificates, configure NTP, block NetBIOS/RPC and X11.	Low findings closed or accepted.

8.1 Governance and process recommendations

- **Hardened build baseline.** Build development servers from an approved image aligned to a CIS Benchmark; prohibit cleartext management protocols.
- **Asset inventory.** Register the server with an owner, purpose, data classification and approved exposure (CIS 1.1; ISO A.5.9).
- **Patch and end-of-life management.** Set SLAs (7/30/90/180 days) and track software end-of-life dates (CIS 2.2, 7.4).
- **Environment segregation.** Keep development and test systems apart from production (ISO A.8.31, A.8.22).
- **Scanning cadence and evidence.** Run monthly authenticated scans; record tool and template versions and save every output file to the evidence folder.
- **Credential management.** Remove default accounts; enforce unique passwords and, where applicable, multi-factor authentication (CIS 4.7, 5.2).

8.2 Retest plan and success measures

1. Repeat the full TCP Nmap scan, Nikto and Nuclei with the same commands; record the Nuclei template version (nuclei -tv).
2. Add a credentialed configuration review and a targeted UDP scan to close limitations L03 and L04.
3. Compare results with this baseline; update each finding status in the register and attach closure evidence.
4. Report residual risk and obtain management sign-off.

Table 19: *Success measures for the retest*

Measure	Baseline (22 Oct 2026)	Target
Critical findings	6	0 within 7 days

Measure	Baseline (22 Oct 2026)	Target
High findings	14	0 within 30 days, or accepted with compensating controls
Open TCP ports	30	Only ports with a documented owner and purpose
Filtered / firewalled ports	0 of 65,535	Default-deny with allow-list
Nuclei critical + high results	22	0
Cleartext management protocols	Telnet, rexec, rlogin, rsh, FTP	None

8.3 Residual risk statement

Until remediation is complete the residual risk equals the inherent risk shown in this report. Isolation of the host (Phase 0) is the only compensating control recommended in the interim; it reduces likelihood but does not remove the underlying weaknesses.

9. Limitations and Evidence Notes

Table 20: *Assessment limitations*

ID	Limitation	Detail	Mitigation / next step	Status
L01	**Nuclei template download failed**	Initial 'nuclei -update-templates' timed out (context deadline exceeded); the first scan stopped with 'no templates provided for scan' and wrote a 0-byte output file.	Resolved: templates were obtained with 'git clone --depth 1 https://github.com/projectdiscovery/nuclei-templates.git ~/nuclei-templates' (14,474 files) and the scan completed with 59 results. Record the template version used and retain the template update log.	Closed
L02	**Scanner results are partly version-based**	Several Nuclei matches (for example CVE-2026-4480, CVE-2015-1419, CVE-2021-30047) rely on version strings, and Nmap/Nikto findings rely on banners.	Validate installed package builds and configuration before treating as confirmed exploitable.	Open
L03	**No credentialed or authenticated testing**	The host was assessed from the network only; no local configuration review, patch inventory or file-system inspection was done.	Perform a credentialed scan or configuration review (for example with Lynis or OpenSCAP) to confirm findings.	Open
L04	**UDP ports not scanned**	Nmap -p- covers TCP only. UDP exposure was seen only where Nuclei probed UDP/137 and UDP/111.	Run a targeted UDP scan (for example nmap -sU --top-ports 100).	Open
L05	**Single point-in-time, same-segment assessment**	Scans ran from 192.168.164.128 on the same subnet on 22 October 2026, so no intermediate firewall was tested and results reflect one moment.	Repeat after remediation and from a representative network location.	Open
L06	**No exploitation performed**	No exploit payloads were run and no interactive shell was opened. Some Nuclei templates send active probes (for example CVE-2011-2523 and CVE-2012-1823).	Obtain explicit approval before any manual validation of backdoors or shells.	Noted
L07	**Possible scanner false positives**	Nikto reported a junk-method response and a '#wp-config.php#' file that may be false positives; the eight FTP weak-credential hits share one anonymous account.	Review each item manually and record the outcome.	Open

9.1 Evidence inventory

Table 21: *Evidence files*

File	Description	Notes
evidence/initial_scan.nmap	Readable Nmap output (6.2 KB)	Saved 05:00
evidence/initial_scan.xml	Nmap XML (26 KB), source for the HTML report	Saved 05:00
evidence/initial_scan.gnmap	Grep-friendly Nmap output (1.8 KB)	Saved 05:00
evidence/initial_scan_report.html	Formatted Nmap report (20 KB)	Generated 05:18 with xsltproc
Nmap Scan Report ... .html and .pdf	Browser copies of the report (21 KB and 59 KB)	Saved 05:22-05:23; screenshots included in the lab report
evidence/nikto_scan.txt	Nikto output (3.4 KB)	Saved 05:31
evidence/nuclei_template_update.txt	Template update failure log (468 bytes)	Records the context deadline exceeded timeout
evidence/nuclei_scan.txt	Nuclei results (59 lines) from the re-run after the template clone	The first file was 0 bytes; make sure the new output replaces it in the evidence folder

9.2 Statements about interpretation

- Service and version banners can be incomplete or misleading; confirm installed package versions before final severity decisions.

- Some Nuclei templates send active probes (for example for CVE-2011-2523 and CVE-2012-1823). No exploit payload was run and no shell was opened.
- CVSS values for CVE-2004-2687 and CVE-2012-1823 are the commonly published NVD values and were not re-checked against NVD during this assessment; CVE-2011-2523, CVE-2020-1938, CVE-2021-30047, CVE-2015-1419 and CVE-2026-4480 were checked against the sources listed in Section 11.
- This assessment was performed against an intentionally vulnerable training target. Do not generalise these results to production assets.

10. Conclusion

The scans identified multiple high-priority exposures on the Metasploitable lab host. The most urgent items are the vsftpd backdoor detected on TCP/6200, the root shell on TCP/1524, the PostgreSQL and VNC default credentials, distccd and the AJP connector, followed by cleartext protocols, obsolete software and the absence of any network filtering. The Nuclei scan, which was incomplete in version 1.0, has now completed and its 59 results are mapped to the register. Remediation should be tracked to closure using the Excel register and verified by a repeat assessment.

The value of this exercise lies in interpreting scanner output to drive business-focused risk decisions: which findings are confirmed, which need validation, which map to control gaps and who must act by when.

11. Sources and References

- NVD, CVE-2011-2523 (vsftpd 2.3.4 backdoor; CVSS v3.1 9.8, v2 10.0): https://nvd.nist.gov/vuln/detail/CVE-2011-2523
- NVD, CVE-2020-1938 (Apache Tomcat AJP, Ghostcat; CVSS v3 9.8; affected 7.0.0-7.0.99, 8.5.0-8.5.50, 9.0.0.M1-9.0.0.30): https://nvd.nist.gov/vuln/detail/CVE-2020-1938
- NVD, CVE-2021-30047 (vsftpd 3.0.3 denial of service; CVSS v3.1 7.5): https://nvd.nist.gov/vuln/detail/CVE-2021-30047
- Wiz vulnerability database, CVE-2015-1419 (vsftpd 3.0.2 and earlier, deny_file; CVSS 5.0 medium): https://www.wiz.io/vulnerability-database/cve/cve-2015-1419
- OSV, CVE-2026-4480 (Samba printing subsystem command injection; CVSS 3.1 9.0; version data inconsistent between sources): https://osv.dev/vulnerability/CVE-2026-4480
- CIS Critical Security Controls v8; NIST Cybersecurity Framework 2.0; ISO/IEC 27001:2022 Annex A; PCI DSS v4.0; OWASP Top 10 2021 (framework identifiers as published by the respective bodies).
- Lab brief: GRC Lab 1, Practical Vulnerability Assessment for GRC Professionals.

Appendix A. Nuclei Results (all results)

Nuclei v3.11.1; 59 results in output order. The last column links each result to a register finding. Severity is the label assigned by the Nuclei template.

Table 22: *Complete Nuclei output with severity and mapped finding*

#	Template ID	Proto	Severity	Target	Detail	Finding
1	**CVE-2012-1823**	http	**High**	192.168.164.129/index.php?-d+allow_url_include%3don+-d+au...		R13
2	**phpmyadmin-panel**	http	**Info**	192.168.164.129/phpMyAdmin/	[paths="/phpMyAdmin/"]	R22
3	**phpinfo-files**	http	**Low**	192.168.164.129/phpinfo.php	[paths="/phpinfo.php"]	R23
4	**http-trace:trace-request**	http	**Info**	192.168.164.129		R33
5	**apache-mod-negotiation-listing:exposed_files**	http	**Low**	192.168.164.129/index	["index.php"] [path="/index"]	R35
6	**php-detect**	http	**Info**	192.168.164.129	["5.2.4"]	R14
7	**waf-detect:apachegeneric**	http	**Info**	192.168.164.129		R35
8	**CVE-2026-4480:version**	javascript	**Critical**	192.168.164.129:445	["3.0.20"]	R11
9	**postgres-default-logins**	javascript	**High**	192.168.164.129:5432	passwords='postgres', usernames='postgres'	R03
10	**vnc-default-login**	javascript	**High**	192.168.164.129:5900	passwords='password'	R06
11	**vnc-default-login**	javascript	**High**	192.168.164.129:5900	passwords='password123'	R06
12	**samba-detect**	javascript	**Info**	192.168.164.129:445	["Samba 3.0.20-Debian"]	R11
13	**pgsql-default-db**	javascript	**High**	192.168.164.129:5432	database='postgres', password='postgres', usernames='postgres'	R03
14	**pgsql-default-db**	javascript	**High**	192.168.164.129:5432	database='postgres', password='', usernames='postgres'	R03
15	**pgsql-default-db**	javascript	**High**	192.168.164.129:5432	database='template1', password='postgres', usernames='postgres'	R03
16	**pgsql-default-db**	javascript	**High**	192.168.164.129:5432	database='template1', password='', usernames='postgres'	R03
17	**ntlm-info**	javascript	**Info**	192.168.164.129:445	["NTLM: Samba 3.0.20-Debian"]	R12
18	**smb-v1-supported**	javascript	**Info**	192.168.164.129:445		R12
19	**smb-version-detect:smb-version**	javascript	**Info**	192.168.164.129:445	["SMB 1.0"]	R12
20	**pgsql-empty-password**	javascript	**Critical**	192.168.164.129:5432		R03
21	**netbios-udp-detect**	javascript	**Info**	192.168.164.129:137	["NetBIOS Name Service Detected"]	R38
22	**rpc-udp-detect**	javascript	**Info**	192.168.164.129:111	["RPC Portmapper UDP Detected"]	R38
23	**CVE-2004-2687**	tcp	**High**	192.168.164.129:3632		R05
24	**CVE-2015-1419:version**	tcp	**Medium**	192.168.164.129:21	["2.3.4"]	R30
25	**CVE-2021-30047:version**	tcp	**High**	192.168.164.129:21	["2.3.4"]	R30
26	**ftp-weak-credentials**	tcp	**High**	192.168.164.129:21	password='password', username='ftp'	R10
27	**ftp-weak-credentials**	tcp	**High**	192.168.164.129:21	password='default', username='ftp'	R10
28	**ftp-weak-credentials**	tcp	**High**	192.168.164.129:21	password='nas', username='ftp'	R10
29	**ftp-detect**	tcp	**Info**	192.168.164.129:21		R10
30	**vsftpd-detect:version**	tcp	**Info**	192.168.164.129:21	["2.3.4"]	R01
31	**nfs-v3-exposed**	tcp	**Info**	192.168.164.129:2049		R21

#	Template ID	Proto	Severity	Target	Detail	Finding
32	**pgsql-detect**	tcp	**Info**	192.168.164.129:5432		R15
33	**openssh-detect**	tcp	**Info**	192.168.164.129:22	["SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1"]	R26
34	**vnc-service-detect**	tcp	**Info**	192.168.164.129:5900	["RFB 003.003"]	R06
35	**CVE-2020-1938**	tcp	**Critical**	192.168.164.129:8009		R04
36	**smtp-detect**	tcp	**Info**	192.168.164.129:25		R32
37	**esmtp-detect**	tcp	**Info**	192.168.164.129:25		R32
38	**smtp-commands-enum:ehlo**	tcp	**Info**	192.168.164.129:25	["DSN","PIPELINING","SIZE 10240000","VRFY","ETRN","STARTTLS","ENHANCEDSTATUSCODES","8BITMIME"]	R32
39	**CVE-2011-2523**	tcp	**Critical**	192.168.164.129:6200		R01
40	**ftp-anonymous-login**	tcp	**Medium**	192.168.164.129:21		R10
41	**ftp-weak-credentials**	tcp	**High**	192.168.164.129:21	password='123456', username='ftp'	R10
42	**ftp-weak-credentials**	tcp	**High**	192.168.164.129:21	password='guest', username='ftp'	R10
43	**ftp-weak-credentials**	tcp	**High**	192.168.164.129:21	password='stingray', username='ftp'	R10
44	**ftp-weak-credentials**	tcp	**High**	192.168.164.129:21	password='pass1', username='ftp'	R10
45	**ftp-weak-credentials**	tcp	**High**	192.168.164.129:21	password='toor', username='ftp'	R10
46	**apache-detect**	http	**Info**	192.168.164.129	["Apache/2.2.8 (Ubuntu) DAV/2"]	R14
47	**apache-httpd-eol:version**	http	**Info**	192.168.164.129	["2.2.8"]	R14
48	**php-eol:version**	http	**Info**	192.168.164.129	["5.2.4"]	R14
49	**tech-detect:php**	http	**Info**	192.168.164.129		R35
50	**http-missing-security-headers:content-security-policy**	http	**Info**	192.168.164.129	Missing header: content-security-policy	R34
51	**http-missing-security-headers:x-content-type-options**	http	**Info**	192.168.164.129	Missing header: x-content-type-options	R34
52	**http-missing-security-headers:x-permitted-cross-domain-policies**	http	**Info**	192.168.164.129	Missing header: x-permitted-cross-domain-policies	R34
53	**http-missing-security-headers:cross-origin-opener-policy**	http	**Info**	192.168.164.129	Missing header: cross-origin-opener-policy	R34
54	**http-missing-security-headers:permissions-policy**	http	**Info**	192.168.164.129	Missing header: permissions-policy	R34
55	**http-missing-security-headers:x-frame-options**	http	**Info**	192.168.164.129	Missing header: x-frame-options	R34
56	**http-missing-security-headers:referrer-policy**	http	**Info**	192.168.164.129	Missing header: referrer-policy	R34
57	**http-missing-security-headers:cross-origin-embedder-policy**	http	**Info**	192.168.164.129	Missing header: cross-origin-embedder-policy	R34
58	**http-missing-security-headers:cross-origin-resource-policy**	http	**Info**	192.168.164.129	Missing header: cross-origin-resource-policy	R34
59	**http-missing-security-headers:strict-transport-security**	http	**Info**	192.168.164.129	Missing header: strict-transport-security	R34

Appendix B. Nikto Results (27 items)

Nikto v2.5.0 against http://192.168.164.129:80. Server banner: Apache/2.2.8 (Ubuntu) DAV/2. 8,910 requests, 0 errors, 27 items reported.

Table 23: *Complete Nikto output with category and mapped finding*

#	Finding reported by Nikto	Path	Category	Finding
1	X-Powered-By header retrieved: PHP/5.2.4-2ubuntu5.10	/	Information disclosure	R35
2	Anti-clickjacking X-Frame-Options header not present	/	Missing header	R34
3	X-Content-Type-Options header not set (MIME sniffing)	/	Missing header	R34
4	Apache/2.2.8 outdated (current is at least 2.4.54; 2.2.34 is EOL for the 2.x branch)	/	Outdated software	R14
5	Uncommon header 'tcn' found, with contents: list	/index	Information disclosure	R35
6	mod_negotiation enabled with MultiViews; alternative 'index.php' found (file-name brute forcing)	/index	Misconfiguration	R35
7	Server returns a valid response with junk HTTP methods (KOVKERUA); possible false positive	/	Behaviour / possible false positive	R35
8	HTTP TRACE method active (suggests vulnerability to XST)	/	Insecure method	R33
9	Output from phpinfo() found	/phpinfo.php	Information disclosure	R23
10	Directory indexing found	/doc/	Directory listing	R24
11	/doc/ directory browsable (may be /usr/doc), CVE-1999-0678	/doc/	Directory listing	R24
12	PHP reveals potentially sensitive information via query string (OSVDB-12184) - ID PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000	/?=PHPB8B5F2A0-...	Information disclosure	R35
13	PHP reveals potentially sensitive information via query string (OSVDB-12184) - ID PHPE9568F36-D428-11d2-A769-00AA001ACF42	/?=PHPE9568F36-...	Information disclosure	R35
14	PHP reveals potentially sensitive information via query string (OSVDB-12184) - ID PHPE9568F34-D428-11d2-A769-00AA001ACF42	/?=PHPE9568F34-...	Information disclosure	R35
15	PHP reveals potentially sensitive information via query string (OSVDB-12184) - ID PHPE9568F35-D428-11d2-A769-00AA001ACF42	/?=PHPE9568F35-...	Information disclosure	R35
16	phpMyAdmin is for managing MySQL databases and should be protected or limited to authorized hosts	/phpMyAdmin/changelog.php	Exposed admin interface	R22
17	Server may leak inodes via ETags; ChangeLog inode 92462, size 40540, mtime 9 Dec 2008 (CVE-2003-1418)	/phpMyAdmin/ChangeLog	Information disclosure	R35
18	phpMyAdmin should be protected or limited to authorized hosts	/phpMyAdmin/ChangeLog	Exposed admin interface	R22
19	Directory indexing found	/test/	Directory listing	R24
20	'This might be interesting' - test content present	/test/	Test content	R24
21	PHP installed and a test script that runs phpinfo() found (CWE-552)	/phpinfo.php	Information disclosure	R23
22	Directory indexing found	/icons/	Directory listing	R24
23	Apache default file found	/icons/README	Default content	R24
24	phpMyAdmin directory found	/phpMyAdmin/	Exposed admin interface	R22
25	phpMyAdmin documentation exposed	/phpMyAdmin/Documentation.html	Exposed admin interface	R22
26	phpMyAdmin README exposed	/phpMyAdmin/README	Exposed admin interface	R22
27	'#wp-config.php#' file reported (may contain credentials) - unverified	/#wp-config.php#	Possible credential exposure	R25

Appendix C. Selected Nmap Script Output

Extracts from the Nmap output (nmap -sV -sC -O -p-), reproduced as captured.

C.1 Scan header

```
# Nmap 7.95 scan initiated Thu Oct 22 04:57:27 2026 as:
/usr/lib/nmap/nmap --privileged -sV -sC -O -p- -oA evidence/initial_scan 192.168.164.129
Host is up (0.0011s latency).
Not shown: 65505 closed tcp ports (reset)
MAC Address: 00:0C:29:5B:0B:68 (VMware)
OS: Linux 2.6.9 - 2.6.33 (100%)
# Nmap done at Thu Oct 22 05:00:32 2026 -- 1 IP address (1 host up) scanned in 184.73 seconds
```

C.2 FTP and SSH (TCP/21, 22)

```
21/tcp open ftp vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst: Connected to 192.168.164.128 / Logged in as ftp / TYPE: ASCII
|   Control connection is plain text / Data connections will be plain text
|   vsFTPd 2.3.4 - secure, fast, stable
22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
```

C.3 SMTP (TCP/25): SSLv2 and certificate

```
25/tcp open smtp Postfix smtpd
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/
|   stateOrProvinceName=There is no such thing outside US/countryName=XX
|   Not valid before: 2010-03-17T14:07:45
|_  Not valid after:  2010-04-16T14:07:45
| sslv2: SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|_    SSL2_DES_64_CBC_WITH_MD5
| smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN,
|_  STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
```

C.4 SMB and host scripts

```
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
Host script results:
| smb-os-discovery: OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable / Domain name: localdomain
|   FQDN: metasploitable.localdomain
| smb-security-mode: account_used: guest, authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb2-time: Protocol negotiation failed (SMB2)
| clock-skew: mean: 1h00m05s, deviation: 2h00m00s, median: 4s
|_nbstat: NetBIOS name: METASPLOITABLE
```

C.5 Other services

```
1524/tcp open bindshell Metasploitable root shell
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5 (Protocol: 10)
3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
```

```
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open vnc VNC (protocol 3.3); Security types: VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd; version: Unreal3.2.8.1. irc.Metasploitable.LAN
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1; http-title: Apache Tomcat/5.5
8787/tcp open drb Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
```

Appendix D. Glossary

Table 24: *Terms and abbreviations*

Term	Meaning
AJP	Apache JServ Protocol, used between a web server and Tomcat.
Banner	Text a service sends that identifies its software and version; may be incomplete or altered.
CIS Controls	Center for Internet Security prioritised safeguards; v8 is used here.
CVE	Common Vulnerabilities and Exposures identifier for a publicly known flaw.
CVSS	Common Vulnerability Scoring System: a 0-10 severity score for a vulnerability, independent of the local environment.
EOL	End of life: the vendor no longer provides security updates.
Inherent risk	Risk before considering the effect of controls, here Likelihood x Impact.
Nuclei template	A YAML test that Nuclei runs to detect a vulnerability or exposure.
NSE	Nmap Scripting Engine; the -sC option runs the default scripts.
Residual risk	Risk remaining after controls and remediation.
SLA	Service level agreement; here the number of days allowed to remediate by rating.
SMB	Server Message Block, the Windows file-sharing protocol implemented by Samba.
XST	Cross-Site Tracing: abuse of the HTTP TRACE method.